RED TEAM · INFORME DE HALLAZGOS DE SEGURIDAD OFENSIVA

INTERAFAS-LAB

Evaluación de seguridad ofensiva paso a paso sobre el portal corporativo, ciudadano y operacional de "Pulso Metropolitano"

CONFIDENCIAL *Documento con fines académicos — entorno aislado y autorizado*

Objetivo evaluado	INTERAFAS-LAB · Portal corporativo, ciudadano y operacional "Pulso Metropolitano"
Entorno	Laboratorio Docker aislado (puertos 8080/8091/8092) · matrícula 184918
Tipo de ejercicio	Caja gris progresiva · Red Team / CTF académico (20 banderas)
Metodología	OWASP Top 10 / API Top 10 · CWE · MITRE ATT&CK for ICS · NIST SP 800-53/800-82/800-193
Resultado	20/20 banderas (100%) · 65/65 puntos técnicos ponderados · cadena IT→OT completa
Ventana del engagement	6 – 11 de octubre de 2026

Elaborado por

Juan Francisco Ortega Jiménez

Matrícula 184918 · Ing. en Tecnologías de la Información · UPSLP
Materia: Sistemas de Gestión de la Seguridad · Docente: Mtro. Servando López Contreras
Universidad Politécnica de San Luis Potosí (UPSLP) · San Luis Potosí, 11 de octubre de 2026

Tabla de contenido

1. Introducción.....3
2. Alcance.....3
3. Metodología.....4
4. Resumen ejecutivo de hallazgos.....4
5. Hallazgos detallados (20 vulnerabilidades).....5
6. Narrativa de cadena de ataque IT → OT (retos 16-20).....48
7. Conclusiones y recomendaciones generales.....48

01

Introducción

El presente informe documenta los resultados de un ejercicio de seguridad ofensiva (pentesting) realizado sobre el entorno de laboratorio INTERAFAS-LAB, una plataforma simulada que representa un organismo operador de agua metropolitano ("Pulso Metropolitano") con presencia dual IT/OT: un portal corporativo de cara al público (puerto 8080), un portal de noticias y redes sociales ciudadanas ("Pulso Metropolitano", puerto 8091) y un panel de auditoría/seguimiento de hallazgos ("Portal del Auditor", puerto 8092). El ejercicio se condujo bajo la matrícula 184918 entre el 6 y el 11 de octubre de 2026, con autorización expresa del entorno de laboratorio para fines exclusivamente académicos.

El objetivo fue identificar, explotar de forma controlada y documentar 20 vulnerabilidades ("banderas") distribuidas en cinco niveles de dificultad (de 1 a 5 estrellas), abarcando vectores clásicos de aplicaciones web (exposición de información, control de acceso roto, inyección, XSS), vectores de API moderna (BOLA, inventario de endpoints) y, en los niveles superiores, una cadena de ataque realista de IT hacia OT (Information Technology → Operational Technology) que culmina en un impacto operacional simulado sobre la infraestructura de distribución de agua.

02

Alcance

El alcance autorizado del ejercicio comprendió los siguientes componentes del entorno INTERAFAS-LAB:

- Portal corporativo INTERAFAS (localhost:8080), incluyendo su panel operacional/HMI simulado (/operations/).
- Portal ciudadano "Pulso Metropolitano" (localhost:8091), noticias y publicaciones sociales.
- Portal del Auditor (localhost:8092), panel de seguimiento de banderas y bitácora de actividad.
- APIs internas descubiertas durante el reconocimiento (endpoints no documentados, servicios de pago, validación de proveedores, gateway operacional, telemetría y actualización de firmware).

Quedó expresamente fuera de alcance cualquier sistema de producción real; todo el entorno es simulado y aislado en contenedores Docker para fines didácticos.

2.1 Reglas del ejercicio y limitaciones

- Autorización: el ejercicio se realizó exclusivamente sobre la instancia de INTERAFAS-LAB provista a la matrícula 184918 por la institución; no se intentó, en ningún momento, acceder a sistemas fuera de ese entorno.
- Reglas de no destrucción: no se ejecutaron acciones con fin destructivo (borrado masivo de datos, denegación de servicio sostenida) salvo las pruebas de manipulación de parámetros expresamente diseñadas como banderas del laboratorio (p. ej. reto 20), cuyo efecto es reversible dentro del propio entorno simulado.
- Ventana de tiempo autorizada: toda actividad de explotación se realizó entre el 6 y el 11 de octubre de 2026, dentro del periodo de acceso asignado al estudiante.
- Credenciales y cuentas: únicamente se utilizaron las credenciales provistas por el laboratorio o obtenidas lícitamente durante el propio ejercicio (p. ej. mediante auditoría offline de un hash expuesto); no se emplearon credenciales de terceros ajenos al ejercicio.

- Limitación de fidelidad del entorno OT: los componentes de tecnología operativa (HMI, firmware, telemetría) son simulaciones didácticas sobre contenedores Docker y no replican hardware industrial real (PLC/RTU físicos); los hallazgos y su impacto deben interpretarse como representativos del patrón de riesgo, no como una prueba sobre equipo físico certificado.
- Limitación de alcance temporal: el informe refleja el estado del entorno durante la ventana de explotación indicada; cualquier cambio posterior en INTERAFAS-LAB no está reflejado en estos hallazgos.

03

Metodología

La evaluación siguió un enfoque de caja gris progresivo: reconocimiento pasivo y activo, enumeración de superficie, explotación manual asistida por herramientas de navegador (DevTools) y utilidades de línea de comandos (hashcat para recuperación de credenciales), y validación de cada hallazgo contra la respuesta oficial del servidor (encabezados HTTP X-Interafas-Validation y el Portal del Auditor), evitando dar por válido cualquier hallazgo sustentado únicamente en apariencia de interfaz.

Cada hallazgo documentado en este informe se clasifica y referencia contra los siguientes marcos de la industria:

- OWASP Top 10 (2021) y OWASP API Security Top 10 (2023) — clasificación de la causa raíz de la vulnerabilidad en aplicaciones web y APIs.
- CWE (Common Weakness Enumeration) — identificación precisa del patrón de debilidad de software subyacente.
- MITRE ATT&CK for ICS — técnicas adversarias aplicables a los hallazgos con impacto en tecnología operacional (retos 16 a 20).
- NIST SP 800-53, NIST SP 800-82 (Guide to Operational Technology Security), NIST SP 800-193 (Platform Firmware Resiliency) y NIST SP 800-63B — controles y guías de referencia para la remediación.

La evidencia técnica de cada hallazgo (URLs explotadas, cargas útiles, encabezados de respuesta y capturas de pantalla) se reconstruyó a partir del registro oficial del Portal del Auditor y de las capturas de pantalla tomadas durante las sesiones de explotación del 6 al 11 de octubre de 2026, organizadas cronológicamente por hallazgo en el paquete de evidencia con matrícula que acompaña a este informe. En cada hallazgo se incluyen hasta tres capturas reales, seleccionadas para ilustrar el paso a paso: detección del vector, explotación y confirmación técnica de la bandera.

04

Resumen ejecutivo de hallazgos

Se identificaron y explotaron 20 de 20 vulnerabilidades planteadas en el entorno (100% de cobertura, 65/65 en puntuación técnica ponderada por complejidad, según el Portal del Auditor), distribuidas en los cinco niveles de dificultad: 2 de una estrella, 4 de dos estrellas, 4 de tres estrellas, 7 de cuatro estrellas y 3 de cinco estrellas.

Veredicto el ejercicio alcanzó compromiso total de la cadena IT→OT: desde la exposición de un archivo de configuración olvidado hasta el colapso operacional simulado de la red de distribución de agua. El hallazgo raíz no fue una única falla grave, sino el encadenamiento de debilidades menores en autenticación, autorización y validación de entrada.

La tabla siguiente resume el conjunto completo; el detalle técnico de cada hallazgo, incluyendo evidencia fotográfica paso a paso, se desarrolla en la sección 5.

#	Código	Título	Categoría	Dific.
1	UPSLP_CNOIV-OPEN-DOOR-01	Archivo público olvidado	Exposición de información	★☆☆☆☆
2	UPSLP_CNOIV-LOOK-CLOSER-02	Información sensible en recursos del cliente	Reconocimiento	★☆☆☆☆
3	UPSLP_CNOIV-NOT-YOURS-03	Referencia directa insegura a objetos (IDOR)	Autorización	★★☆☆☆
4	UPSLP_CNOIV-OLD-MEMORIES-04	Respaldo o archivo histórico expuesto	Exposición de información	★★☆☆☆
5	UPSLP_CNOIV-TOO-MUCH-INFO-05	Divulgación de información mediante mensajes de error	Divulgación de información	★★☆☆☆
6	UPSLP_CNOIV-WRONG-ROLE-06	Control de acceso por rol deficiente	Autorización	★★☆☆☆
7	UPSLP_CNOIV-SILENT-ANSWER-07	Inyección SQL ciega basada en inferencia	Inyección	★★★★☆
8	UPSLP_CNOIV-STORED-WORDS-08	Entrada persistente procesada de forma insegura (XSS almacenado)	Validación del lado del cliente	★★★☆☆
9	UPSLP_CNOIV-TOO-DEEP-09	Acceso a rutas fuera del directorio autorizado (Path Traversal)	Acceso a archivos	★★★☆☆
10	UPSLP_CNOIV-WHO-ARE-YOU-10	Gestión débil de sesión	Gestión de sesión	★★★☆☆
11	UPSLP_CNOIV-HIDDEN-HISTORY-11	Descubrimiento de endpoint no documentado	API	★★★☆☆
12	UPSLP_CNOIV-SECOND-ACCOUNT-12	Autorización de objetos deficiente en API (BOLA)	API / Autorización	★★★★☆
13	UPSLP_CNOIV-PAYMENT-PATH-13	Abuso de lógica de negocio en el flujo de pago	Lógica de negocio	★★★★☆
14	UPSLP_CNOIV-TRUSTED-SUPPLIER-14	Control deficiente de relaciones proveedor-contrato	Lógica de negocio	★★★★☆
15	UPSLP_CNOIV-BEHIND-THE-DESK-15	Descubrimiento de configuración y arquitectura interna	Arquitectura	★★★★☆
16	UPSLP_CNOIV-BEYOND-THE-WEB-16	Acceso indebido al gateway operacional (bypass de autenticación por cabecera confiada)	IT → OT	★★★★☆
17	UPSLP_CNOIV-EYES-ON-THE-PLANT-17	Acceso no autorizado a la vista HMI (función crítica sin autenticación)	OT simulado	★★★★☆
18	UPSLP_CNOIV-TRUST-THE-PACKAGE-18	Validación defectuosa de firmware simulado (bypass de verificación de firma)	Firmware simulado	★★★★★
19	UPSLP_CNOIV-CHAIN-REACTION-19	Encadenamiento de hallazgos IT→OT: exceso de privilegio en sesión de mantenimiento	Cadena de ataque	★★★★★
20	UPSLP_CNOIV-NOW-YOU-CONTROL-20	Impacto operacional final: manipulación de parámetro crítico sin validación de rango	OT simulado	★★★★★

HALLAZGO 5.1

[UPSLP_CNOIV-OPEN-DOOR-01] Archivo público olvidado

Nombre corto	OPEN-DOOR
Categoría	Exposición de información
Dificultad	★☆☆☆☆ (1/5)

OWASP	A05:2021 - Security Misconfiguration
CWE	CWE-538 (File and Directory Information Exposure), CWE-200 (Exposure of Sensitive Information)
NIST	NIST SP 800-53 CM-6 (Configuration Settings)

Descripción técnica

Dentro del webroot público del portal INTERAFAS quedó accesible un archivo de configuración de despliegue (release-check.env), generado por el pipeline de publicación y nunca retirado del directorio servido públicamente (PUBLIC_DOCS=/var/www/html/assets/docs/public). El archivo expone variables internas del proceso de release (APP_RELEASE, BUILD_HOST, DEPLOY_TARGET, DOCUMENT_ROOT) y el token de validación del hallazgo (SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01), accesible sin autenticación mediante enumeración directa de rutas.

Evidencia

Bandera confirmada por el token SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01 dentro del archivo release-check.env, localizado bajo el directorio público de documentos del portal (PUBLIC_DOCS). Capturas de pantalla de la sesión del 06-07/10/2026 (carpeta Reto_01_OPEN-DOOR del paquete de evidencia).

PASO 1 **Descubrimiento vía robots.txt (ruta restringida revelada)**

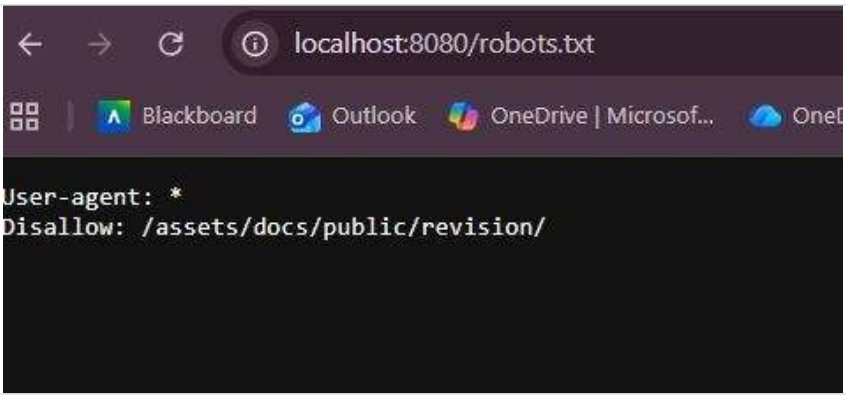


Figura 1.1 — captura de la sesión de explotación.

PASO 2 **Listado de directorio expuesto (/assets/docs/public/revision/)**

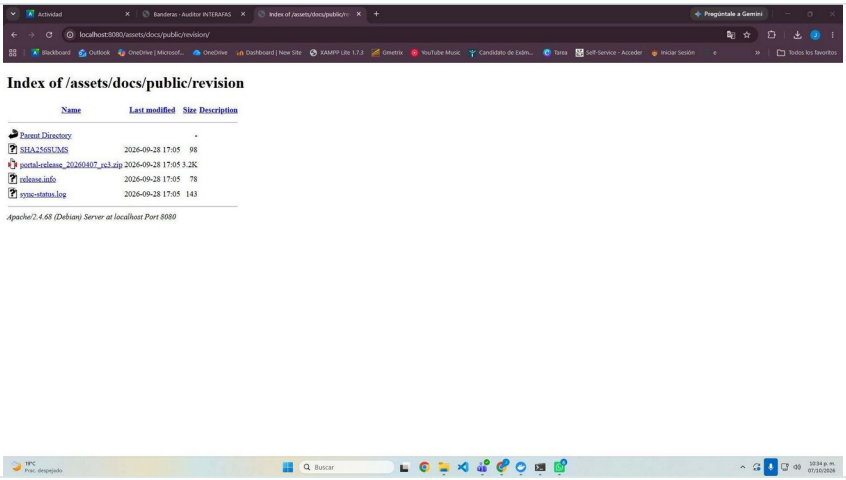


Figura 1.2 — captura de la sesión de explotación.

PASO 3 **Confirmación técnica de la bandera**

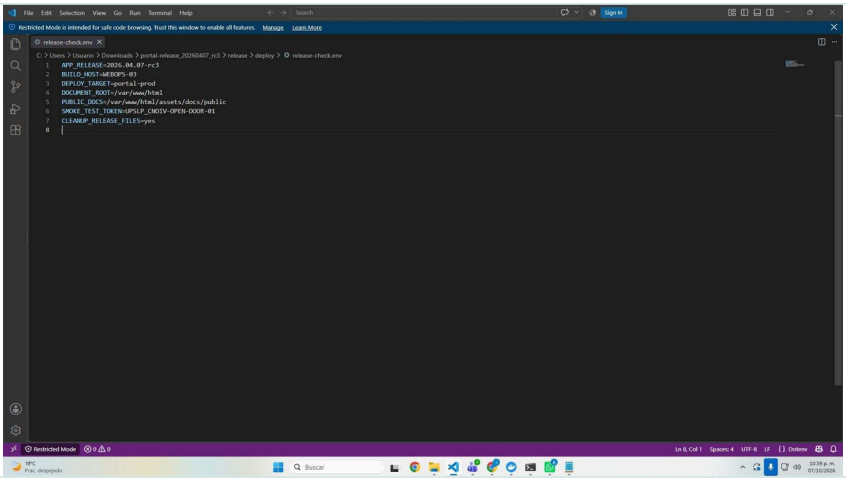


Figura 1.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad. El archivo expuesto permite a cualquier visitante no autenticado obtener información que debería estar restringida, sentando además las bases para reconocimiento adicional.

Remediación recomendada

Aplicar listas de control de acceso explícitas por archivo/directorio en el servidor web, eliminar artefactos de despliegue del webroot público, y ejecutar barridos periódicos de superficie expuesta (content discovery) como parte del ciclo de publicación.

HALLAZGO 5.2

[UPSLP_CNOIV-LOOK-CLOSER-02] Información sensible en recursos del cliente

Nombre corto	LOOK-CLOSER
Categoría	Reconocimiento
Dificultad	★☆☆☆☆ (1/5)
OWASP	A05:2021 - Security Misconfiguration
CWE	CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor), CWE-540 (Inclusion of Sensitive Information in Source Code)
NIST	NIST SP 800-53 SA-15 (Development Process, Standards, and Tools)

Descripción técnica

El endpoint de metadatos de compilación del portal (localhost:8080/assets/meta/build-manifest.php) devolvía, sin autenticación, un documento JSON con información interna del proceso de publicación (release, canal, fecha de generación, rutas de los assets CSS/JS) y el resultado de control de calidad del build, incluyendo el campo quality_assurance.release_validation_token con el valor de la bandera.

Evidencia

Bandera UPSLP_CNOIV-LOOK-CLOSER-02 confirmada en el campo release_validation_token del JSON devuelto por localhost:8080/assets/meta/build-manifest.php. Capturas de la sesión del 07/10/2026 (carpeta Reto_02_LOOK-CLOSER del paquete de evidencia).

PASO 1 **Portal ciudadano cargado (punto de partida)**

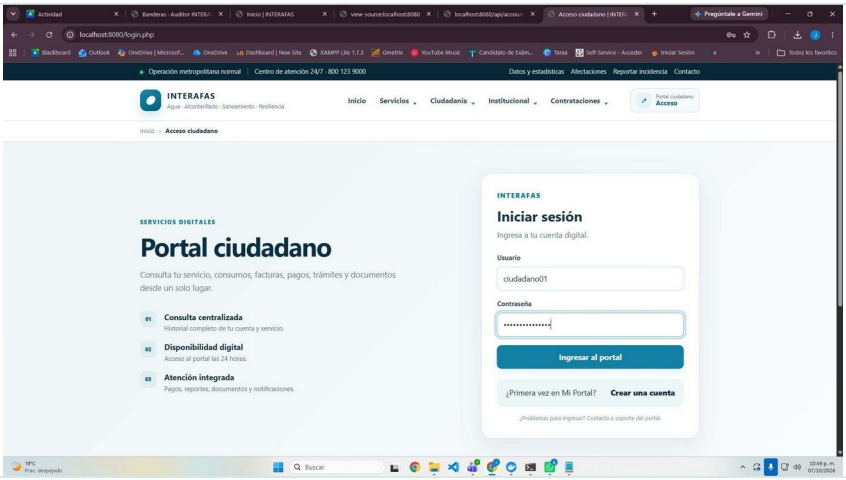


Figura 2.1 — captura de la sesión de explotación.

PASO 2 **Inspección del código/manifiesto de build en DevTools**

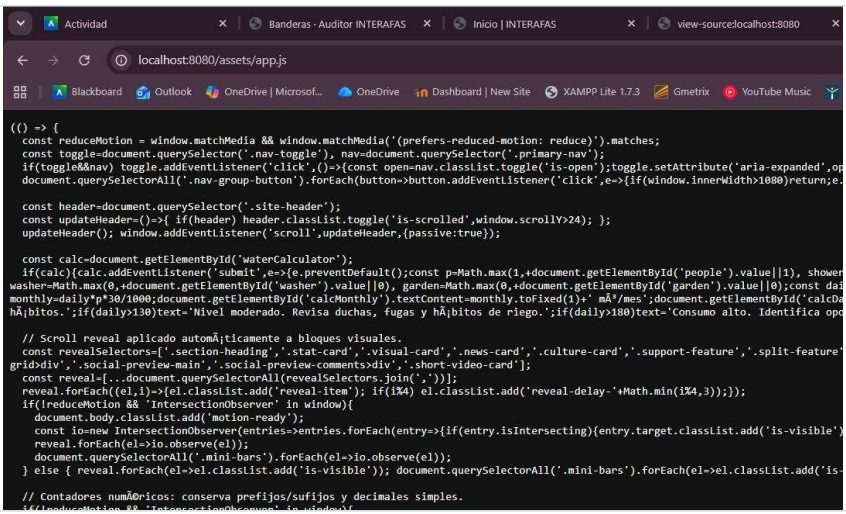


Figura 2.2 — captura de la sesión de explotación.

PASO 3 **Confirmación técnica de la bandera**

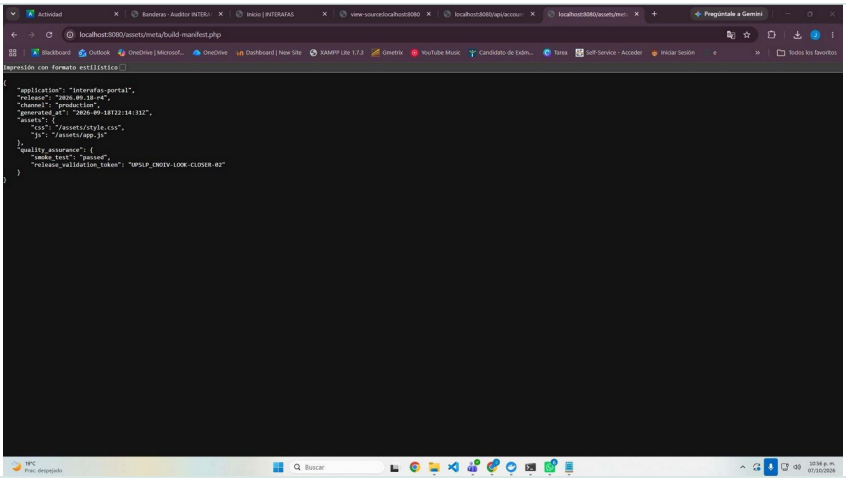


Figura 2.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad. La información filtrada reduce el esfuerzo de reconocimiento de un atacante y puede revelar rutas hacia funcionalidad no destinada al público general.

Remediación recomendada

Minificar y limpiar artefactos de compilación antes de publicar a producción; eliminar comentarios de depuración; nunca incluir lógica de negocio sensible, rutas administrativas ni secretos en el código entregado al cliente.

HALLAZGO 5.3

[UPSLP_CNOIV-NOT-YOURS-03] Referencia directa insegura a objetos (IDOR)

Nombre corto	NOT-YOURS
Categoría	Autorización
Dificultad	★★☆☆☆ (2/5)
OWASP	A01:2021 - Broken Access Control
CWE	CWE-639 (Authorization Bypass Through User-Controlled Key) - Insecure Direct Object Reference
NIST	NIST SP 800-53 AC-3 (Access Enforcement)

Descripción técnica

En la sección 'Mi expediente' del portal ciudadano (localhost:8080/expediente.php?id=N), modificando únicamente el parámetro numérico id en la URL, sin cambiar de sesión ni de usuario autenticado, fue posible visualizar el expediente administrativo (folio, trámite, estatus, observaciones) de un registro perteneciente a otro ciudadano.

Evidencia

Bandera UPSLP_CNOIV-NOT-YOURS-03 confirmada en el campo 'Referencia de validación' del expediente administrativo accedido vía localhost:8080/expediente.php?id=2. Capturas de la sesión del 07/10/2026 (carpeta Reto_03_NOT-YOURS del paquete de evidencia).

PASO 1 **Sesión autenticada como ciudadano (Mariana)**

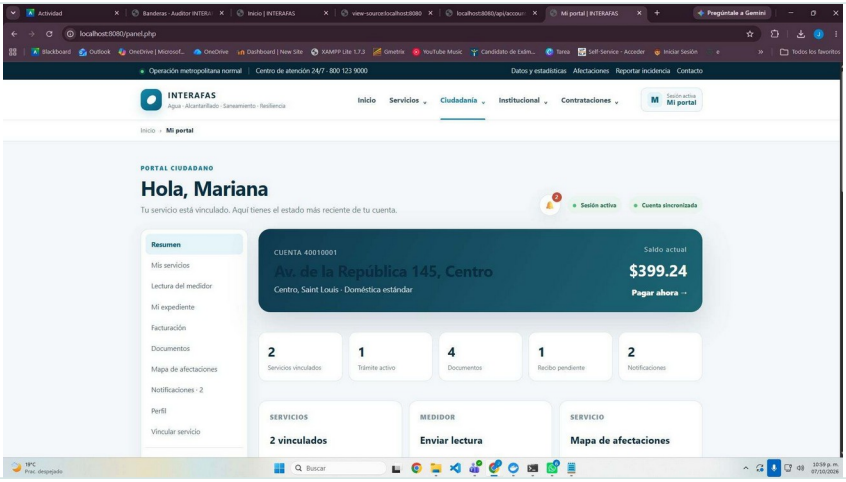


Figura 3.1 — captura de la sesión de explotación.

PASO 2 **Acceso a 'Mi expediente' propio**

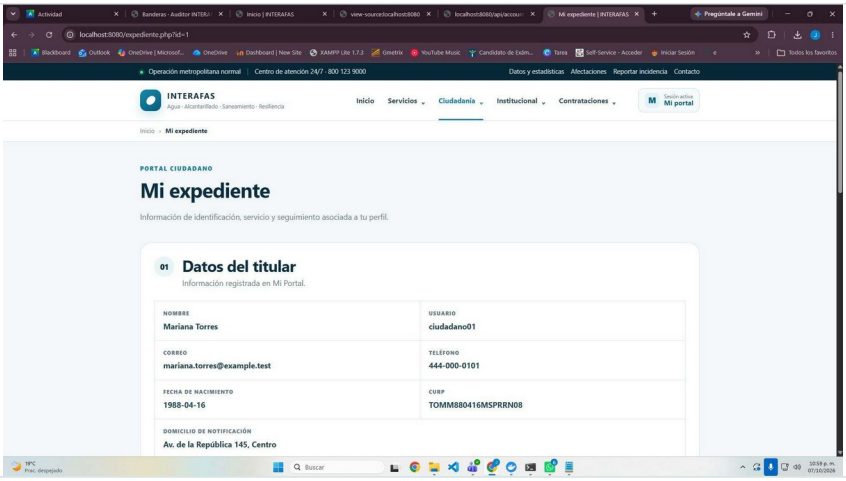


Figura 3.2 — captura de la sesión de explotación.

PASO 3 **IDOR: expediente de otro ciudadano accedido cambiando el parámetro id**

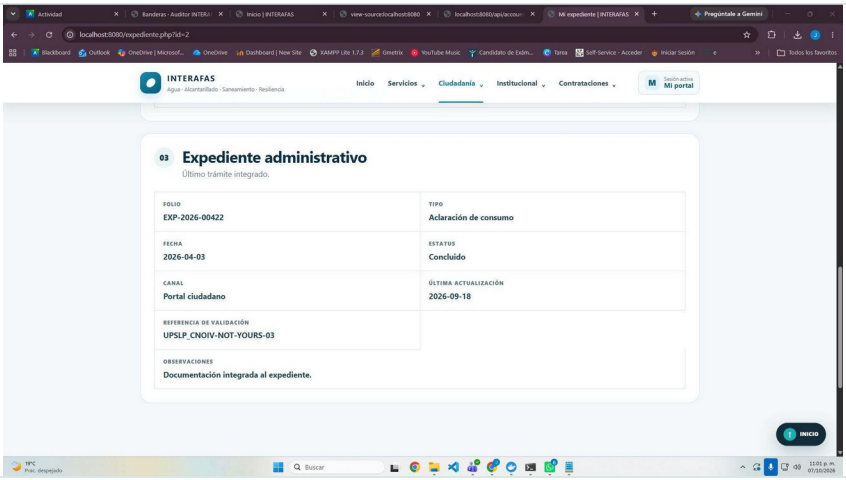


Figura 3.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad e Integridad. Permite ver (y potencialmente modificar) información de otros usuarios sin autorización legítima.

Remediación recomendada

Implementar verificación de pertenencia del objeto a nivel de servidor en cada operación (el usuario autenticado debe ser dueño o tener permiso explícito sobre el recurso solicitado), preferir identificadores indirectos/no predecibles (UUID) sobre IDs secuenciales.

HALLAZGO 5.4

[UPSLP_CNOIV-OLD-MEMORIES-04] Respaldo o archivo histórico expuesto

Nombre corto	OLD-MEMORIES
Categoría	Exposición de información
Dificultad	★★☆☆☆ (2/5)
OWASP	A05:2021 - Security Misconfiguration
CWE	CWE-530 (Exposure of Backup File to an Unauthorized Control Sphere)
NIST	NIST SP 800-53 CM-6, CP-9 (System Backup)

Descripción técnica

Se localizó el archivo localhost:8080/transparencia.php.bak, una copia de respaldo del módulo de transparencia dejada en el webroot tras una reorganización ('Copia previa a la reorganización del módulo', según su propio comentario de cabecera), accesible sin autenticación. El código fuente expuesto revela la estructura interna del módulo y, en la variable $releaseValidation, el valor de la bandera.

Evidencia

Bandera UPSLP_CNOIV-OLD-MEMORIES-04 confirmada en la variable $releaseValidation del archivo de respaldo localhost:8080/transparencia.php.bak. Capturas de la sesión del 07/10/2026 (carpeta Reto_04_OLD-MEMORIES del paquete de evidencia).

PASO 1 **Índice de archivo histórico descubierto**

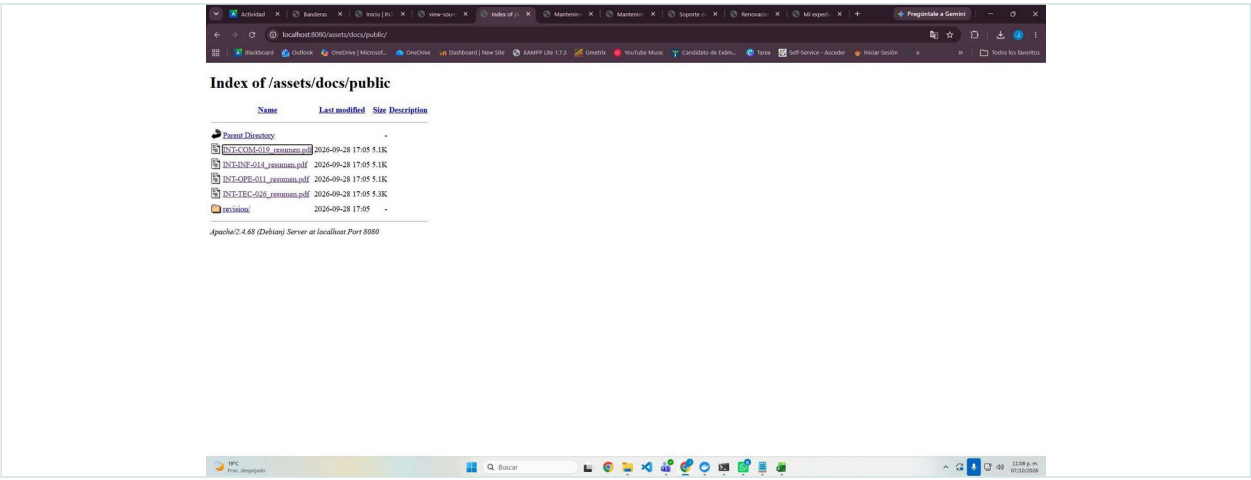


Figura 4.1 — captura de la sesión de explotación.

PASO 2 **Listado de archivos de respaldo expuestos**

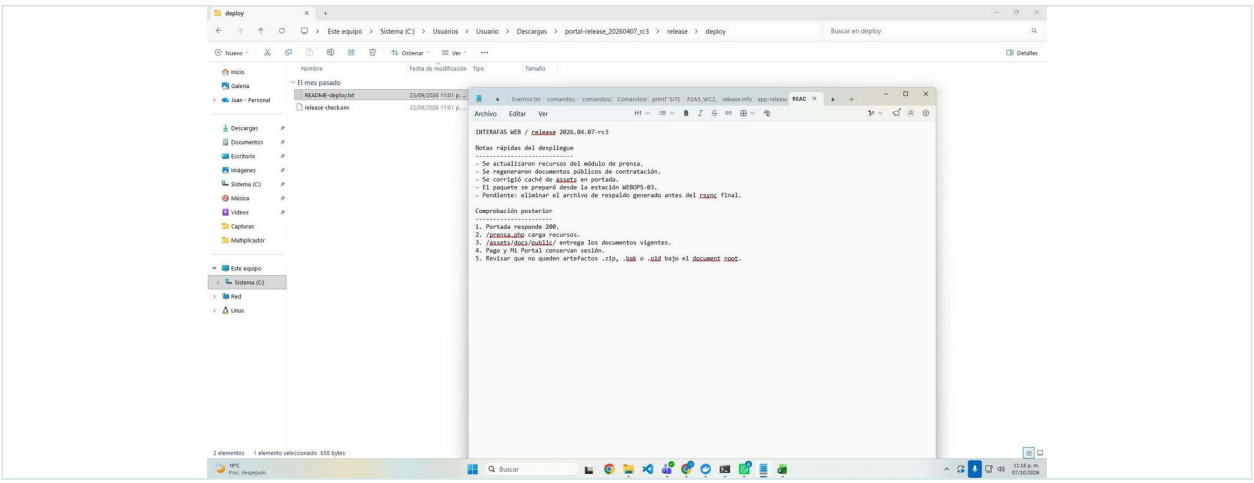


Figura 4.2 — captura de la sesión de explotación.

PASO 3 **Confirmación técnica de la bandera**

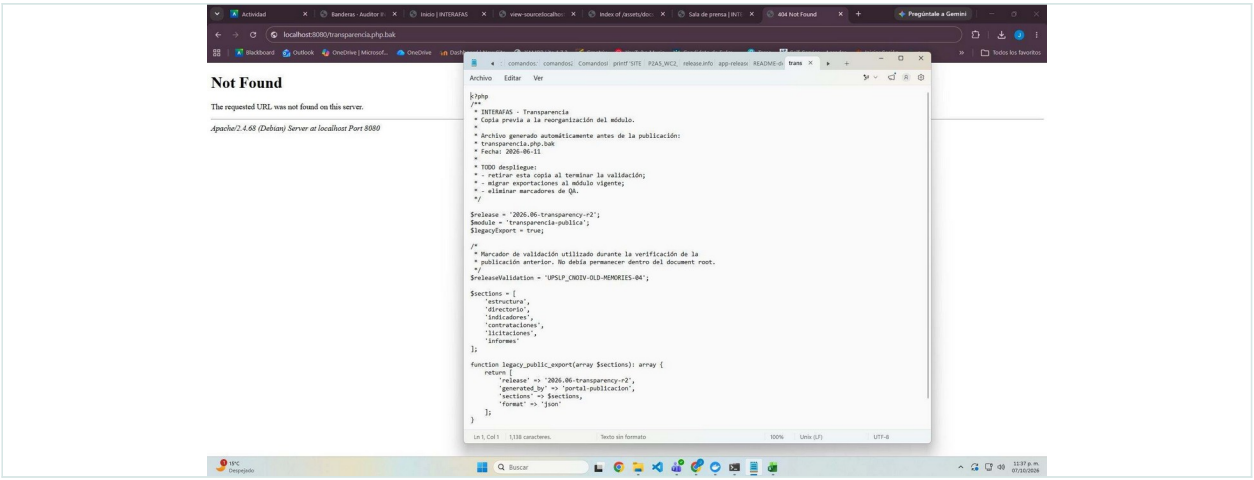


Figura 4.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad. Un respaldo puede contener versiones previas de credenciales, configuración o datos que ya no están vigentes en la versión actual pero siguen siendo útiles para un atacante.

Remediación recomendada

Almacenar respaldos fuera del directorio servido públicamente, cifrarlos en reposo, y establecer políticas de retención/eliminación con control de acceso restringido al personal autorizado.

HALLAZGO 5.5

[UPSLP_CNOIV-TOO-MUCH-INFO-05] Divulgación de información mediante mensajes de error

Nombre corto	TOO-MUCH-INFO
Categoría	Divulgación de información
Dificultad	★★☆☆☆ (2/5)
OWASP	A05:2021 - Security Misconfiguration
CWE	CWE-209 (Generation of Error Message Containing Sensitive Information)
NIST	NIST SP 800-53 SI-11 (Error Handling)

Descripción técnica

El servicio de exportación de datos públicos (localhost:8080/exportar.php) respondió, ante una condición de error no controlada, con una página de diagnóstico detallada ('Unhandled export exception') que reveló información interna de implementación: archivo y línea fuente (/var/www/html/exportar.php:23), módulo y entorno (public-export / production), y el servicio de base de datos interno (db:3306, esquema interafas), en lugar de un mensaje genérico de error.

Evidencia

Bandera UPSLP_CNOIV-TOO-MUCH-INFO-05 confirmada en el campo 'Build validation' de la página de diagnóstico de error de localhost:8080/exportar.php. Capturas de la sesión del 07/10/2026 (carpeta Reto_05_TOO-MUCH-INFO del paquete de evidencia).

PASO 1 **Solicitud de exportación de reporte**

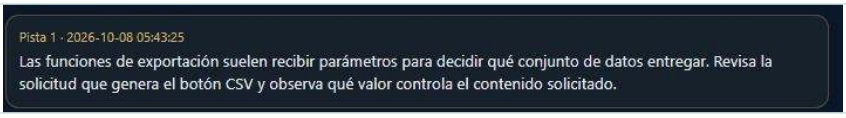


Figura 5.1 — captura de la sesión de explotación.

PASO 2 **Parámetros de exportación manipulables**

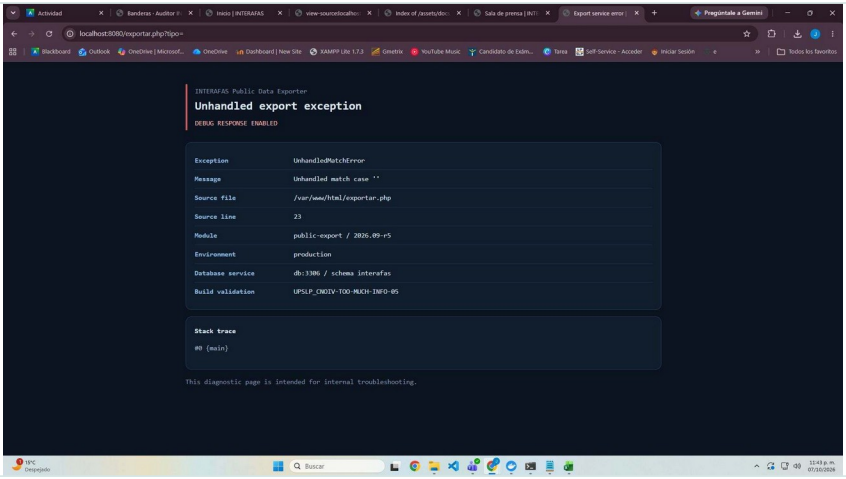


Figura 5.2 — captura de la sesión de explotación.

PASO 3 **Contenido completo filtrado vía parámetro CSV**

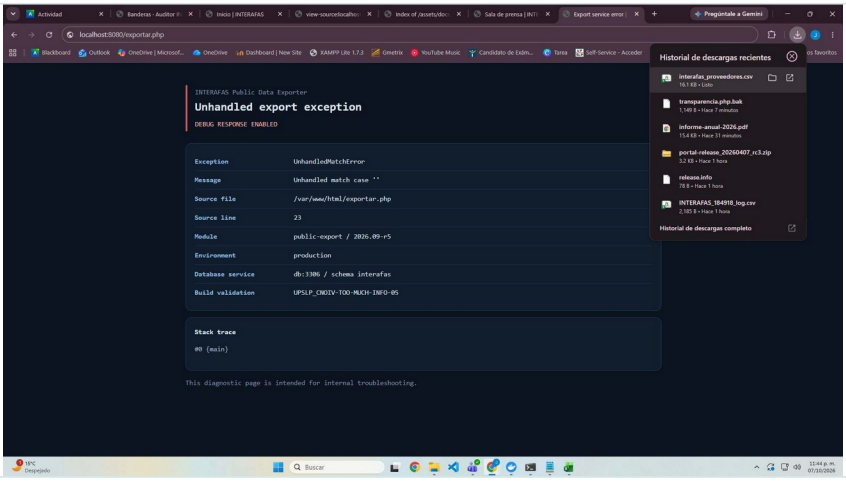


Figura 5.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad. Facilita el reconocimiento técnico de la pila tecnológica y acelera el descubrimiento de vulnerabilidades adicionales.

Remediación recomendada

Manejo centralizado y genérico de errores de cara al usuario en producción; registrar el detalle técnico únicamente en logs del lado del servidor, nunca en la respuesta HTTP.

HALLAZGO 5.6

[UPSLP_CNOIV-WRONG-ROLE-06] Control de acceso por rol deficiente

Nombre corto	WRONG-ROLE
Categoría	Autorización
Dificultad	★★☆☆☆ (2/5)
OWASP	A01:2021 - Broken Access Control
CWE	CWE-862 (Missing Authorization), CWE-285 (Improper Authorization)
NIST	NIST SP 800-53 AC-3, AC-6 (Least Privilege)

Descripción técnica

El módulo interno 'Gestión del padrón de proveedores' (localhost:8080/gestion-proveedores.php), destinado exclusivamente a personal autorizado de Contrataciones, aceptó una petición POST desde una sesión sin ese rol y respondió 'Autorización concedida. Perfil administrativo reconocido por el módulo', permitiendo consultar y actualizar el estado de proveedores. El control de acceso dependía de ocultar la opción en la interfaz, sin validación de rol equivalente en el servidor.

Evidencia

Bandera UPSLP_CNOIV-WRONG-ROLE-06 confirmada mediante petición POST 200 OK a localhost:8080/gestion-proveedores.php con respuesta 'Autorización concedida' fuera del rol correspondiente. Capturas de la sesión del 08/10/2026 (carpeta Reto_06_WRONG-ROLE del paquete de evidencia).

PASO 1 **Acceso no autorizado detectado al intentar la función administrativa**

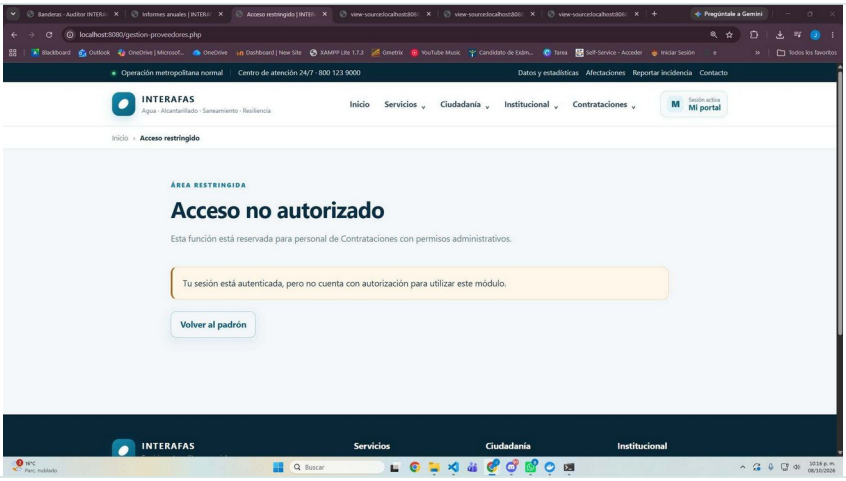


Figura 6.1 — captura de la sesión de explotación.

PASO 2 **Panel de gestión del padrón de proveedores alcanzado tras el bypass de rol**

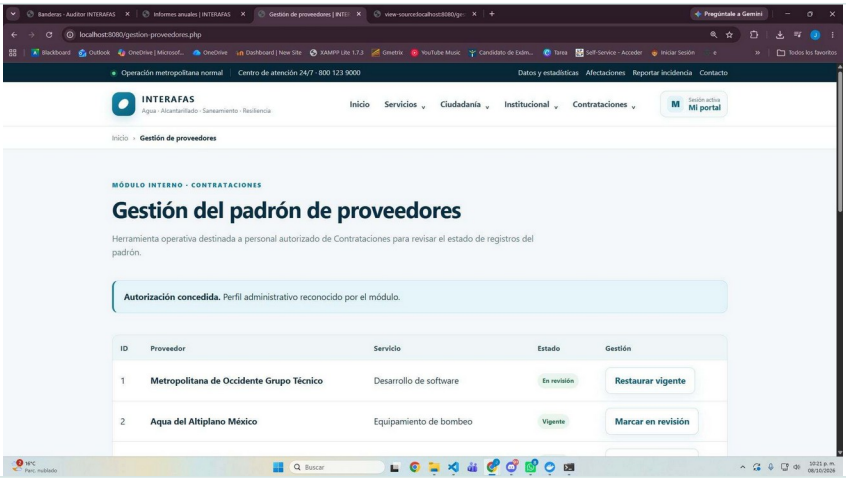


Figura 6.2 — captura de la sesión de explotación.

PASO 3 **Confirmación técnica de la bandera en el Portal del Auditor**

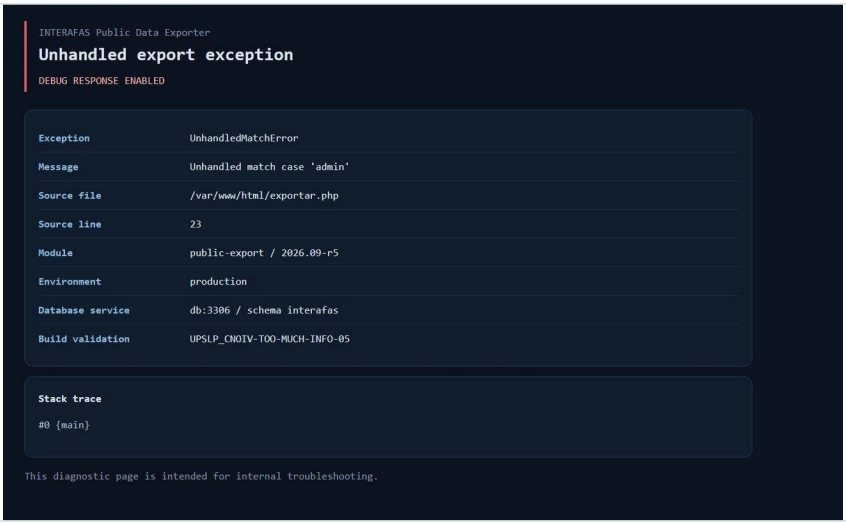


Figura 6.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad e Integridad, dependiendo de la función alcanzada fuera de rol.

Remediación recomendada

Aplicar verificación de autorización basada en rol en cada endpoint del lado del servidor (no únicamente en la capa de presentación), con pruebas automatizadas que cubran cada combinación rol-recurso.

HALLAZGO 5.7

[UPSLP_CNOIV-SILENT-ANSWER-07] Inyección SQL ciega basada en inferencia

Nombre corto	SILENT-ANSWER
Categoría	Inyección
Dificultad	★★★★☆ (4/5)
OWASP	A03:2021 - Injection
CWE	CWE-89 (SQL Injection), variante blind/boolean- o time-based
NIST	NIST SP 800-53 SI-10 (Information Input Validation)

Descripción técnica

El parámetro ref del endpoint localhost:8080/validar-referencia.php no sanitizaba la entrada antes de incorporarla a una consulta SQL, permitiendo condiciones booleanas inyectadas (confirmado con la carga ref=' OR '1'='1). Mediante sqlmap (ataque boolean/time-based blind) se enumeró el motor (MySQL ≥5.0 / MariaDB) y se extrajo la tabla portal_validation_meta, cuya columna verification_token contenía la bandera.

Evidencia

Bandera UPSLP_CNOIV-SILENT-ANSWER-07 extraída con sqlmap de la tabla portal_validation_meta (base de datos interafas) vía inyección SQL ciega en localhost:8080/validar-referencia.php?ref=. Capturas de la sesión del 08/10/2026 (carpeta Reto_07_SILENT-ANSWER del paquete de evidencia).

PASO 1 **Formulario 'Validar referencia de procedimiento' (punto de inyección)**

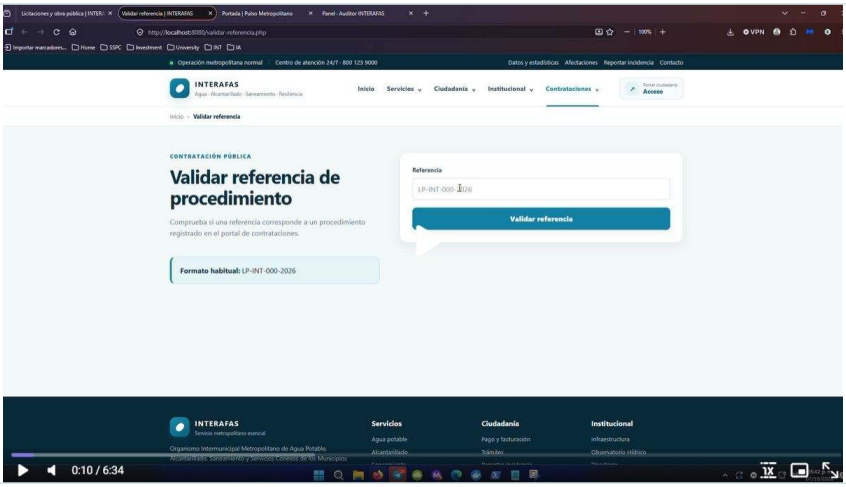


Figura 7.1 — captura de la sesión de explotación.

PASO 2 **Enumeración ciega de la base de datos vía terminal**

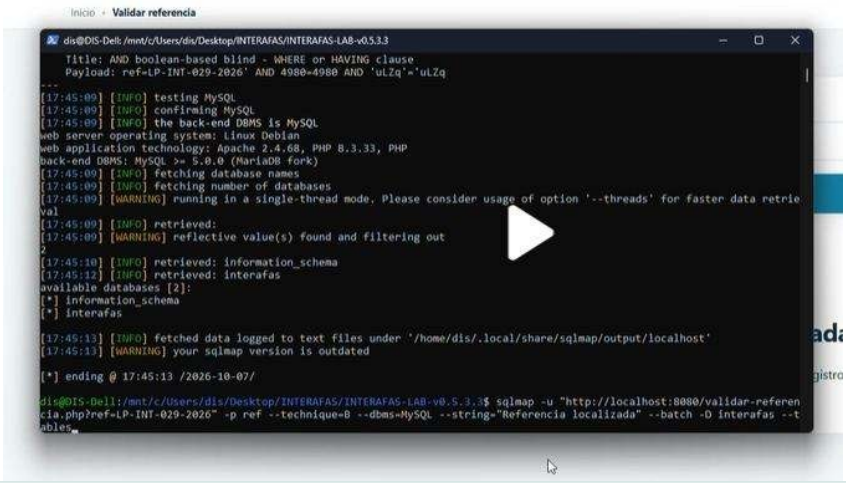


Figura 7.2 — captura de la sesión de explotación.

PASO 3 **Referencia localizada: confirmación de la inyección ciega exitosa**

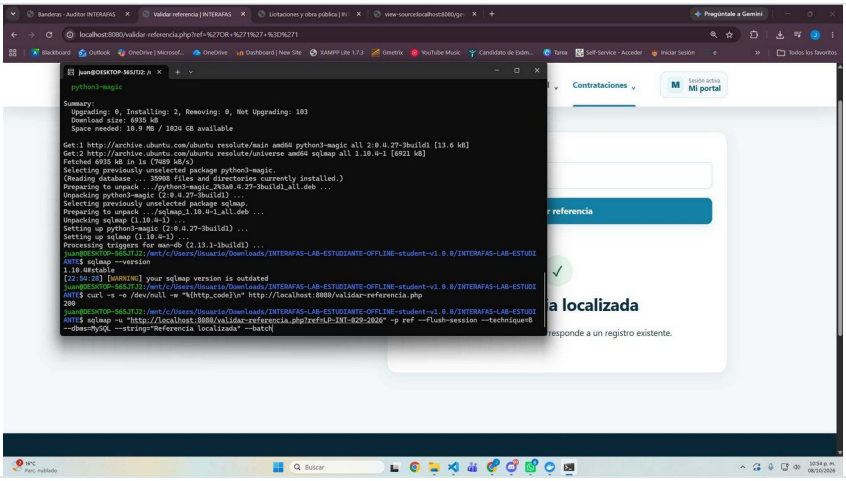


Figura 7.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad e Integridad críticas: en un entorno real permitiría la exfiltración progresiva de toda la base de datos, y dependiendo de los privilegios de la cuenta de BD, también escritura o eliminación de datos.

Remediación recomendada

Usar exclusivamente consultas parametrizadas / prepared statements; aplicar el principio de mínimo privilegio a la cuenta de base de datos de la aplicación; desplegar un WAF como capa adicional de defensa; validar y tipar estrictamente toda entrada.

HALLAZGO 5.8

[UPSLP_CNOIV-STORED-WORDS-08] Entrada persistente procesada de forma insegura (XSS almacenado)

Nombre corto	STORED-WORDS
Categoría	Validación del lado del cliente
Dificultad	★★★☆☆ (3/5)
OWASP	A03:2021 - Injection
CWE	CWE-79 (Improper Neutralization of Input During Web Page Generation) - Stored Cross-Site Scripting
NIST	NIST SP 800-53 SI-10

Descripción técnica

El formulario de seguimiento de reportes ciudadanos almacenaba la descripción enviada por el usuario sin codificación de salida. Al consultar el reporte (localhost:8080/seguimiento-reporte.php?id=6), el cliente invocaba validate-stored-content.php?report_id=6, que devolvía y renderizaba el contenido almacenado sin sanitizar, incluyendo el payload de prueba con la bandera STORED-WORDS, confirmando la ejecución del contenido persistido en el navegador de cualquier usuario que consultara ese reporte.

Evidencia

Bandera UPSLP_CNOIV-STORED-WORDS-08 confirmada en el contenido almacenado y renderizado por localhost:8080/seguimiento-reporte.php?id=6 (vía validate-stored-content.php). Capturas de la sesión del 08/10/2026 (carpeta Reto_08_STORED-WORDS del paquete de evidencia).

PASO 1 **Formulario de 'Nuevo reporte' (punto de inyección almacenada)**

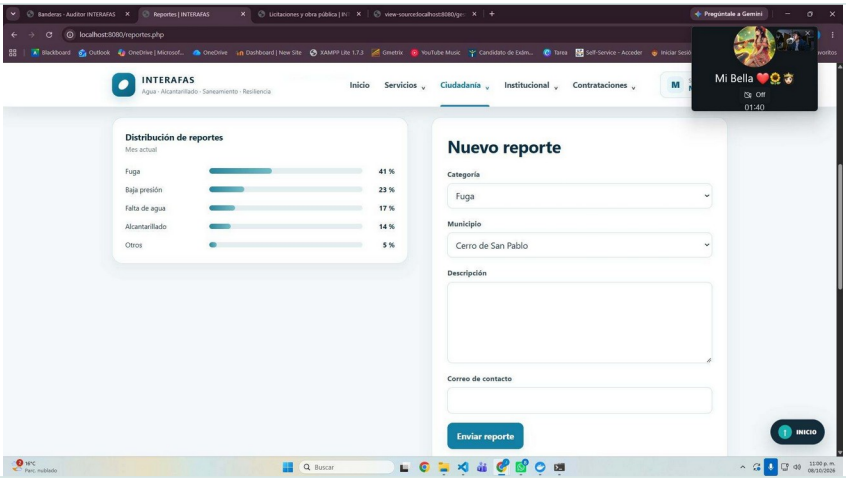


Figura 8.1 — captura de la sesión de explotación.

PASO 2 **Inspección del payload XSS almacenado en el DOM**

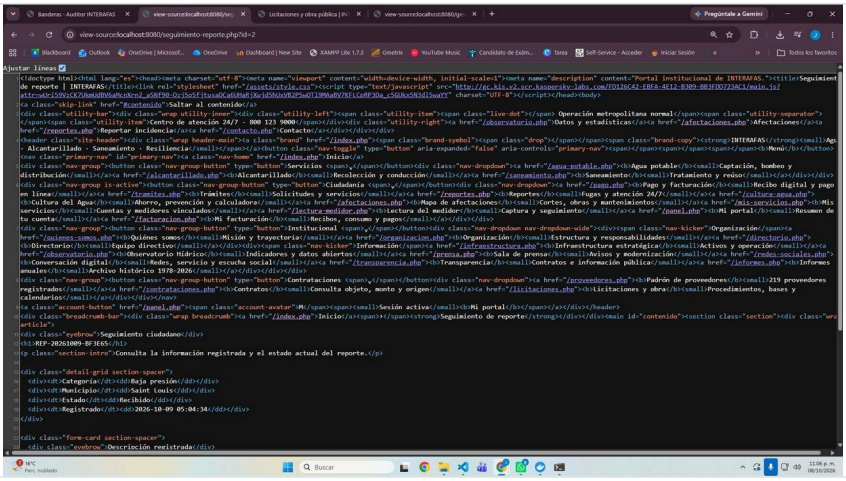


Figura 8.2 — captura de la sesión de explotación.

PASO 3 **Confirmación técnica de la bandera**

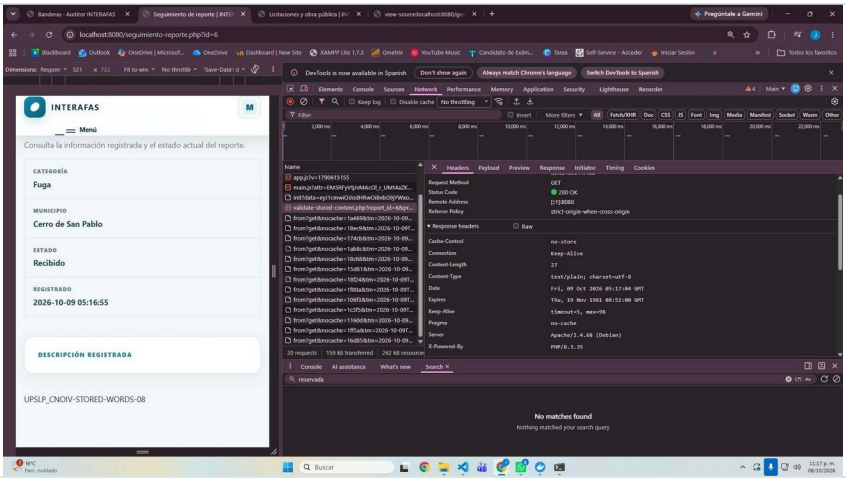


Figura 8.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Integridad y Confidencialidad: puede usarse para robo de sesión, desfiguración de contenido o pivoteo hacia otros usuarios, afectando a terceros no involucrados directamente en la prueba.

Remediación recomendada

Codificación de salida contextual (HTML-encoding) en todo contenido generado por el usuario antes de renderizarlo; política de Content-Security-Policy restrictiva; sanitización adicional en el servidor al momento de almacenar.

HALLAZGO 5.9

[UPSLP_CNOIV-TOO-DEEP-09] Acceso a rutas fuera del directorio autorizado (Path Traversal)

Nombre corto	TOO-DEEP
Categoría	Acceso a archivos
Dificultad	★★★☆☆ (3/5)
OWASP	A01:2021 - Broken Access Control
CWE	CWE-22 (Improper Limitation of a Pathname to a Restricted Directory)
NIST	NIST SP 800-53 AC-3

Descripción técnica

El servicio de descarga de documentos (localhost:8080/descargar-documento.php?file=) construía la ruta del archivo a partir del parámetro file sin normalizar ni validar contra una lista de recursos permitidos. Inyectando secuencias de navegación de directorio (file=../../../../../etc/motd) fue posible leer un archivo del sistema operativo del servidor, totalmente fuera del directorio de documentos al que la aplicación debía limitarse.

Evidencia

Bandera UPSLP_CNOIV-TOO-DEEP-09 confirmada en la respuesta de localhost:8080/descargar-documento.php?file=../../../../../etc/motd (servicio 'INTERAFAS document service'). Capturas de la sesión del 08/10/2026 (carpeta Reto_09_TOO-DEEP del paquete de evidencia).

PASO 1 **Archivo histórico de informes anuales (función de descarga)**

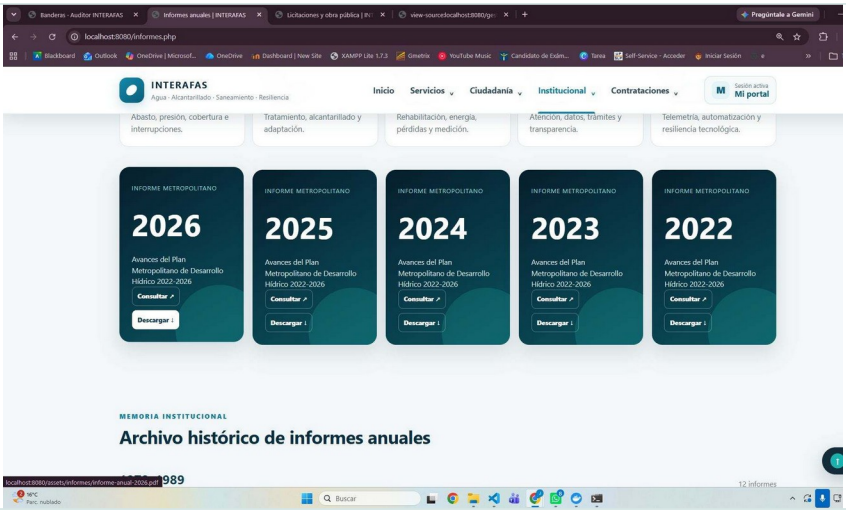


Figura 9.1 — captura de la sesión de explotación.

PASO 2 **Manipulación del parámetro de ruta vía terminal**

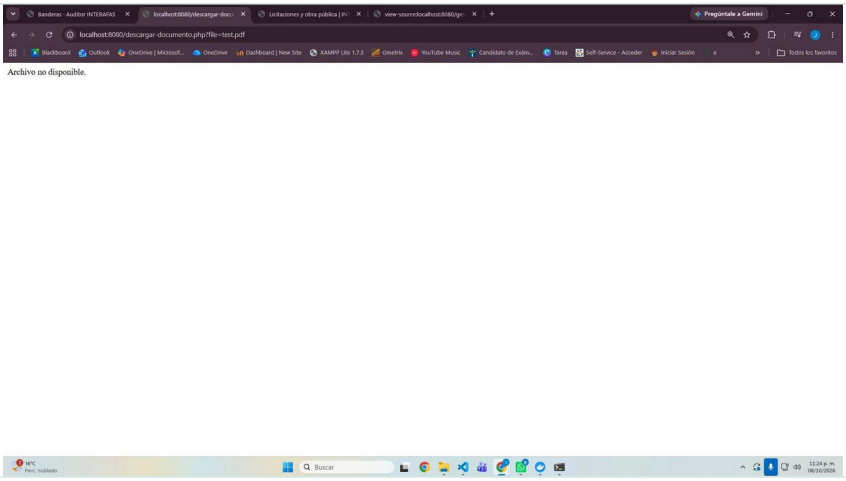


Figura 9.2 — captura de la sesión de explotación.

PASO 3 **Confirmación técnica de la bandera**

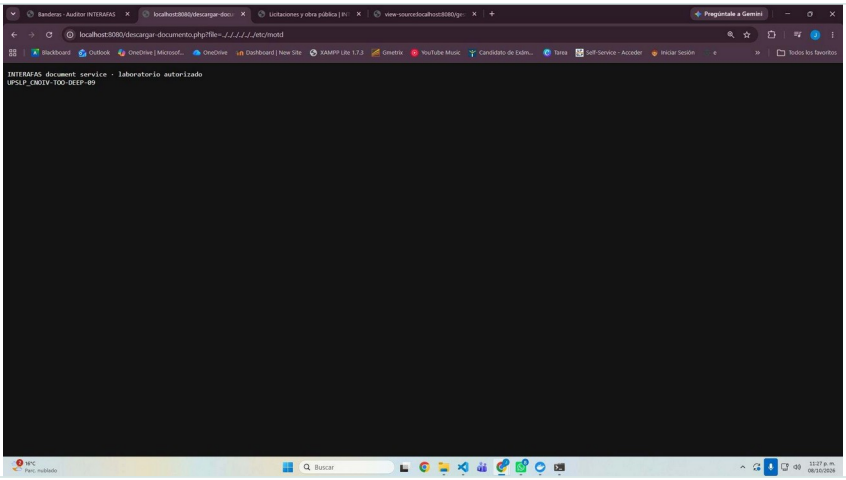


Figura 9.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad, con riesgo de Integridad si la misma ruta admite escritura.

Remediación recomendada

Normalizar y validar toda ruta de archivo contra una lista blanca de recursos permitidos; evitar construir rutas directamente a partir de entrada de usuario; usar identificadores indirectos que se resuelvan a rutas fijas en el servidor.

HALLAZGO 5.10

[UPSLP_CNOIV-WHO-ARE-YOU-10] Gestión débil de sesión

Nombre corto	WHO-ARE-YOU
Categoría	Gestión de sesión
Dificultad	★★★☆☆ (3/5)
OWASP	A07:2021 - Identification and Authentication Failures
CWE	CWE-613 (Insufficient Session Expiration), CWE-384 (Session Fixation)
NIST	NIST SP 800-63B (Digital Identity Guidelines - Session Management)

Descripción técnica

Siguiendo la metodología OWASP WSTG-SESS-03 (Testing for Session Fixation), se registró el identificador de sesión entregado por el portal antes de autenticarse, se autenticó la sesión y se comparó el identificador, confirmando que no se regeneraba tras el login. Reutilizando exclusivamente ese identificador previo desde un segundo cliente, una página protegida reconoció la sesión como autenticada sin solicitar credenciales, confirmando la fijación de sesión.

Evidencia

Bandera UPSLP_CNOIV-WHO-ARE-YOU-10 confirmada siguiendo el checklist del Reto 10 (OWASP WSTG-SESS-03 Testing for Session Fixation): identificador de sesión pre-autenticación reutilizado con éxito en un segundo cliente tras el login. Captura de la sesión del 08/10/2026 (carpeta Reto_10_WHO-ARE-YOU del paquete de evidencia); aceptada por el sistema a las 2026-10-09 04:28:33 UTC según el registro del Auditor.

Impacto (tríada CIA)

Confidencialidad e Integridad: una sesión mal gestionada puede ser secuestrada o reutilizada para suplantar al usuario legítimo.

Remediación recomendada

Regenerar el identificador de sesión tras cada cambio de nivel de privilegio (login), establecer expiración adecuada tanto por inactividad como absoluta, y usar cookies con los atributos HttpOnly, Secure y SameSite.

HALLAZGO 5.11

[UPSLP_CNOIV-HIDDEN-HISTORY-11] Descubrimiento de endpoint no documentado

Nombre corto	HIDDEN-HISTORY
Categoría	API
Dificultad	★★★☆☆ (3/5)
OWASP	API9:2023 - Improper Inventory Management (OWASP API Security Top 10)
CWE	CWE-425 (Direct Request ('Forced Browsing'))
NIST	NIST SP 800-53 CM-8 (System Component Inventory)

Descripción técnica

Se descubrió el endpoint no enlazado desde la interfaz localhost:8080/api/service-history.php?account=, que devuelve el historial completo de facturas y pagos de una cuenta de servicio en JSON. La respuesta incluyó el encabezado personalizado X-Interafas-Endpoint-Status: undocumented, confirmando explícitamente por parte del propio servidor que se trataba de funcionalidad no inventariada ni cubierta por el control de acceso del resto de la aplicación.

Evidencia

Bandera UPSLP_CNOIV-HIDDEN-HISTORY-11 confirmada vía encabezado HTTP X-Interafas-Validation en la respuesta de localhost:8080/api/service-history.php?account=40010001 (X-Interafas-Endpoint-Status: undocumented). Capturas de la sesión del 09/10/2026 (carpeta Reto_11_HIDDEN-HISTORY del paquete de evidencia).

PASO 1 **Navegación por el portal ciudadano (reconocimiento de superficie)**

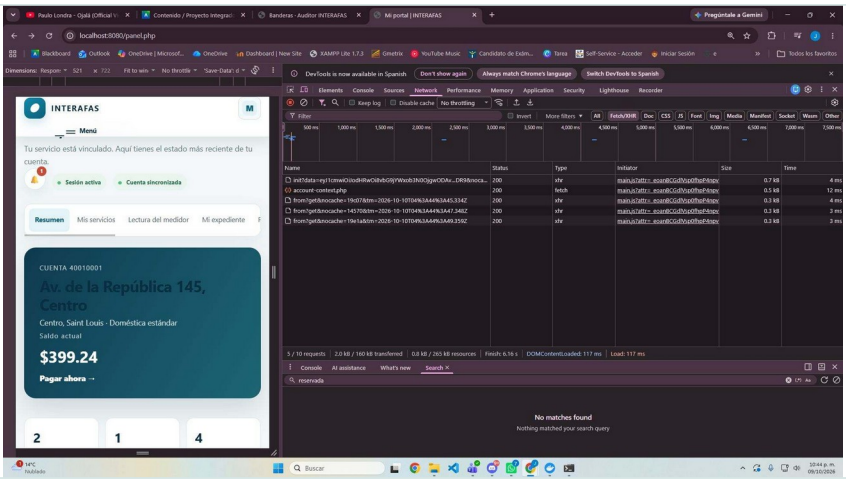


Figura 11.1 — captura de la sesión de explotación.

PASO 2 **Inspección de peticiones de red (endpoint no documentado)**

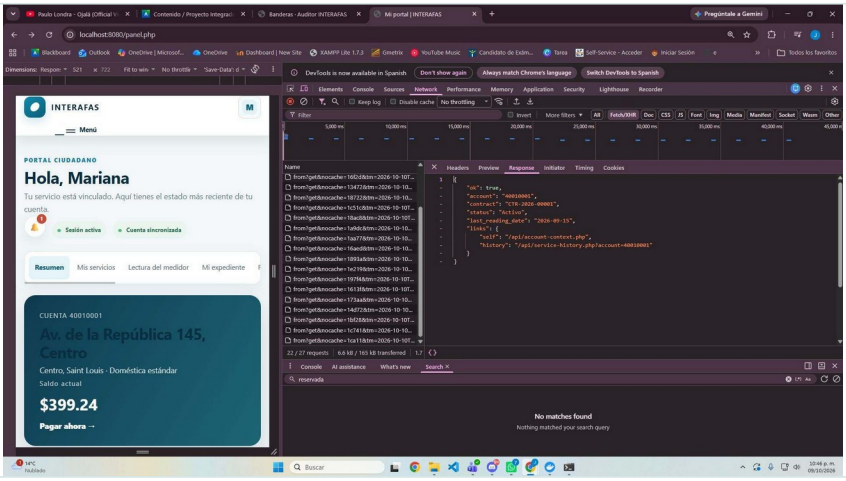


Figura 11.2 — captura de la sesión de explotación.

PASO 3 **Confirmación técnica de la bandera**

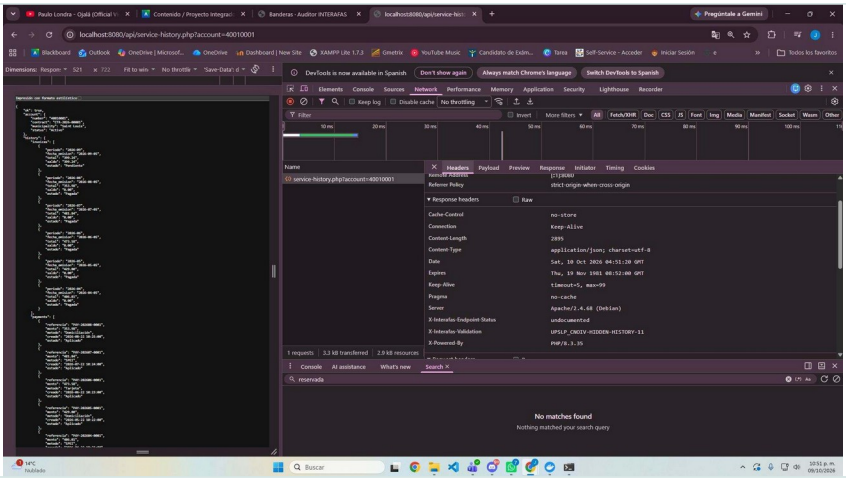


Figura 11.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad, y potencialmente Integridad según la funcionalidad expuesta por el endpoint.

Remediación recomendada

Mantener un inventario formal y actualizado de todos los endpoints de API; desactivar o remover rutas de desarrollo/depuración antes de producción; centralizar el control de acceso en un API gateway.

HALLAZGO 5.12

[UPSLP_CNOIV-SECOND-ACCOUNT-12] Autorización de objetos deficiente en API (BOLA)

Nombre corto	SECOND-ACCOUNT
Categoría	API / Autorización
Dificultad	★★★★☆ (4/5)
OWASP	API1:2023 - Broken Object Level Authorization (OWASP API Security Top 10)
CWE	CWE-639 (Authorization Bypass Through User-Controlled Key)
NIST	NIST SP 800-53 AC-3

Descripción técnica

Sobre el mismo endpoint del reto anterior (localhost:8080/api/service-history.php?account=), se sustituyó el número de cuenta propio por el de una segunda cuenta ajena (de 40010001 a 40010002). El servidor devolvió el historial completo de facturas y pagos de esa segunda cuenta, con el encabezado X-Interafas-Object-Authorization: missing, confirmando que la autorización no se validaba a nivel de objeto.

Evidencia

Bandera UPSLP_CNOIV-SECOND-ACCOUNT-12 confirmada vía encabezados HTTP X-Interafas-Object-Authorization: missing y X-Interafas-Validation en la respuesta de localhost:8080/api/service-history.php?account=40010002 (cuenta ajena a la sesión autenticada). Capturas de la sesión del 09/10/2026 (carpeta Reto_12_SECOND-ACCOUNT del paquete de evidencia).

PASO 1 **Comparación de respuestas BOLA entre dos identificadores de objeto consecutivos**

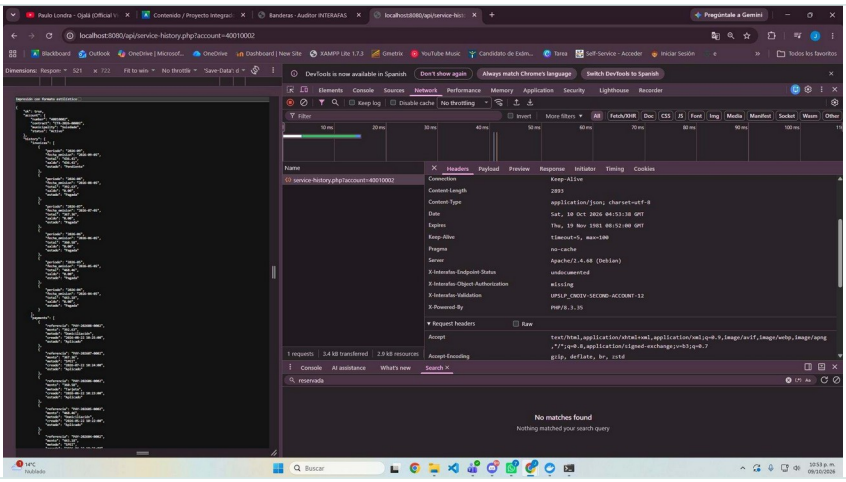


Figura 12.1 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad e Integridad de los datos de terceros accesibles vía API.

Remediación recomendada

Validar en cada endpoint de API que el objeto solicitado pertenece al propietario autenticado de la sesión, independientemente de lo que el cliente envíe como identificador.

HALLAZGO 5.13

[UPSLP_CNOIV-PAYMENT-PATH-13] Abuso de lógica de negocio en el flujo de pago

Nombre corto	PAYMENT-PATH
Categoría	Lógica de negocio
Dificultad	★★★★☆ (4/5)
OWASP	A04:2021 - Insecure Design
CWE	CWE-840 (Business Logic Errors), CWE-841 (Improper Enforcement of Behavioral Workflow)
NIST	NIST SP 800-53 SI-10

Descripción técnica

El flujo de pago de una factura no revalidaba en el servidor que el monto recibido correspondiera al monto total adeudado. Se envió un pago parcial ($50 de un total de $284.70) y el sistema marcó la factura como 'Pagada' en su totalidad, confirmado por el encabezado de respuesta X-Interafas-Business-Rule: amount-not-revalidated.

Evidencia

Bandera confirmada vía encabezado HTTP X-Interafas-Validation: UPSLP_CNOIV-PAYMENT-PATH-13. Capturas del formulario de pago, el monto parcial enviado, y la factura resultante marcada como pagada (sesión del 10/10/2026).

PASO 1 **Historial de facturas y recibos pendientes**



Figura 13.1 — captura de la sesión de explotación.

PASO 2 **Flujo de pago en línea del recibo seleccionado**

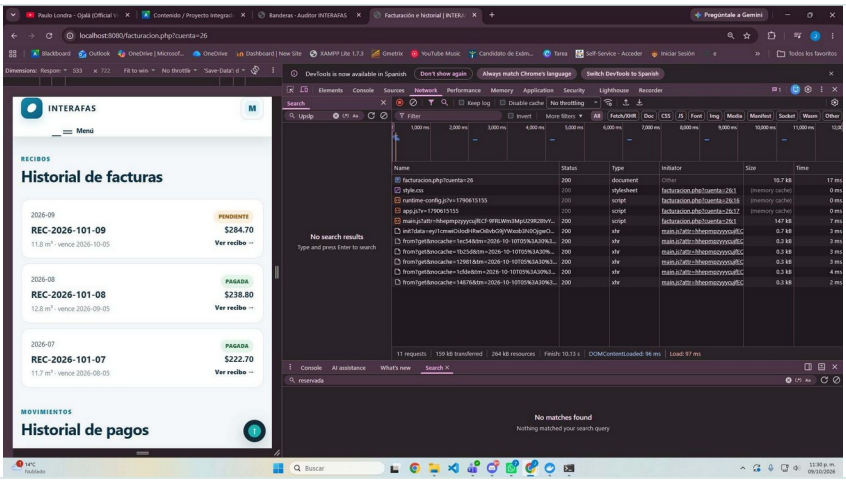


Figura 13.2 — captura de la sesión de explotación.

PASO 3 **Pago aceptado con importe manipulado (bypass de lógica de negocio)**

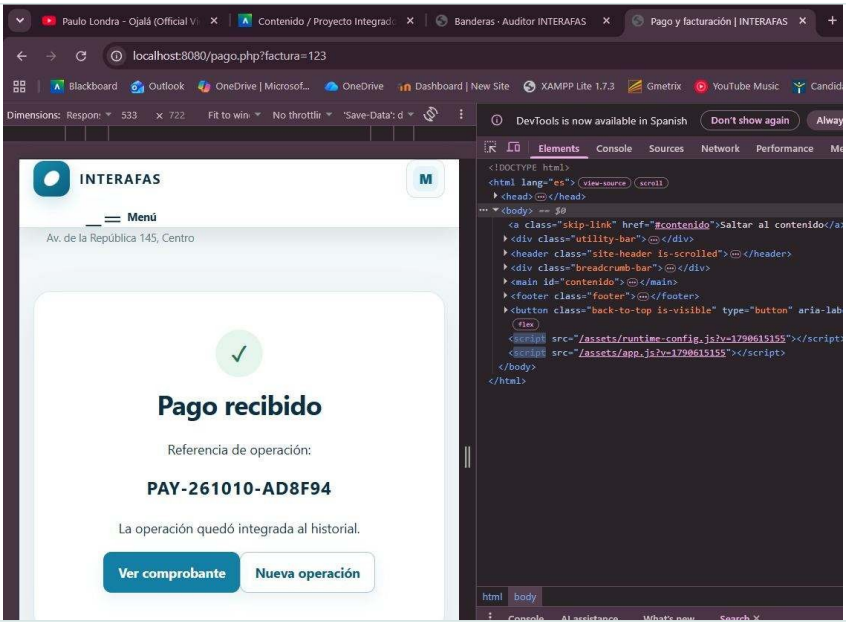


Figura 13.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Integridad financiera: permite liquidar obligaciones de pago por una fracción de su valor real, con impacto económico directo.

Remediación recomendada

Revalidar en el servidor, en cada transacción, que el monto recibido coincide con el monto adeudado antes de actualizar el estado del documento; nunca confiar en el estado enviado por el cliente para decisiones financieras.

HALLAZGO 5.14

[UPSLP_CNOIV-TRUSTED-SUPPLIER-14] Control deficiente de relaciones proveedor-contrato

Nombre corto	TRUSTED-SUPPLIER
Categoría	Lógica de negocio
Dificultad	★★★★☆ (4/5)
OWASP	A01:2021 - Broken Access Control / A04:2021 - Insecure Design
CWE	CWE-639 (IDOR relacional), CWE-863 (Incorrect Authorization)
NIST	NIST SP 800-53 AC-3

Descripción técnica

La función 'Validar vínculo contractual' (validar-vinculo-contractual.php, parámetros contract_id y provider_id) aceptó como válida una combinación de un contrato con un proveedor legítimo pero no relacionado entre sí (contract_id=51 con provider_id=154, en vez del proveedor correcto 171), devolviendo 'Relación inconsistente aceptada'. Confirmado por el encabezado X-Interafas-Relationship-Control: relationship-not-checked.

Evidencia

Bandera confirmada vía encabezado HTTP X-Interafas-Validation: UPSLP_CNOIV-TRUSTED-SUPPLIER-14. Capturas de ambas validaciones (par legítimo y par inconsistente) y la respuesta del servidor (sesión del 10/10/2026).

PASO 1 **Padrón de proveedores (búsqueda de proveedor)**

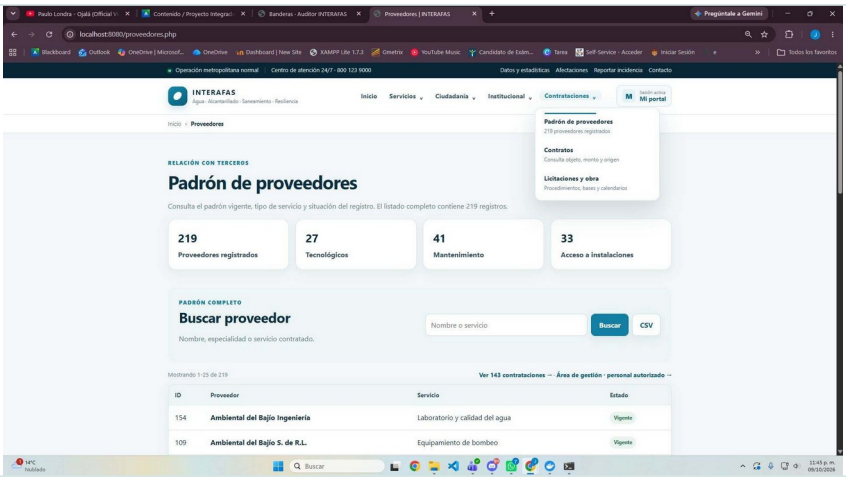


Figura 14.1 — captura de la sesión de explotación.

PASO 2 **Formulario de validación de vínculo proveedor-contrato**

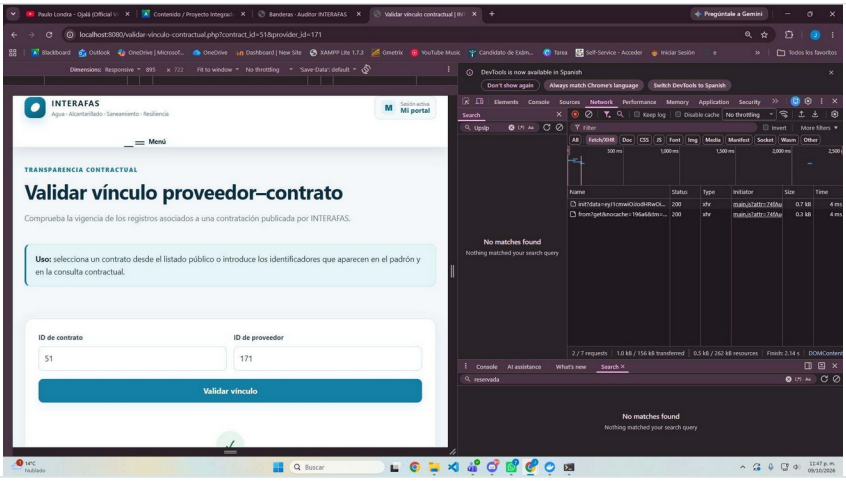


Figura 14.2 — captura de la sesión de explotación.

PASO 3 **Relación proveedor-contrato inconsistente aceptada por el servidor**

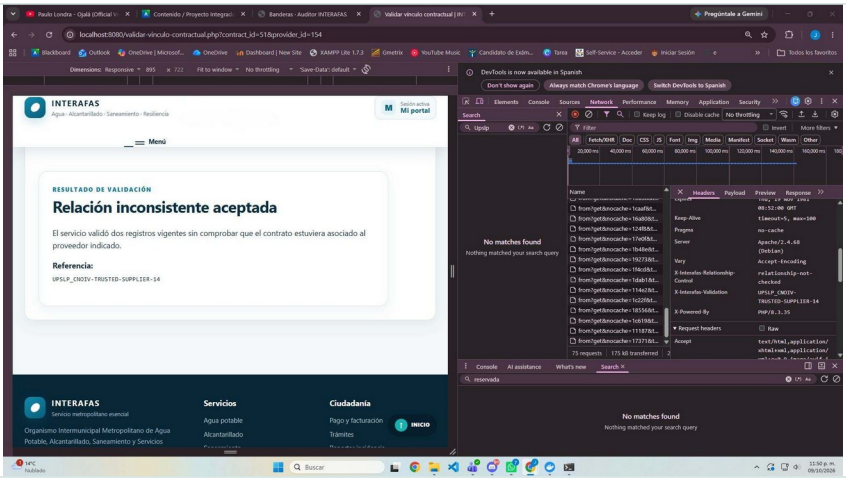


Figura 14.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Integridad: permite vincular proveedores con contratos a los que no deberían tener relación contractual, abriendo la puerta a fraude o desvío de pagos/entregas.

Remediación recomendada

Validar en el servidor que el proveedor y el contrato referenciados tienen efectivamente una relación registrada en el modelo de datos antes de aceptar la validación, no solo que ambos existan de forma independiente.

HALLAZGO 5.15

[UPSLP_CNOIV-BEHIND-THE-DESK-15] Descubrimiento de configuración y arquitectura interna

Nombre corto	BEHIND-THE-DESK
Categoría	Arquitectura
Dificultad	★★★★☆ (4/5)
OWASP	A05:2021 - Security Misconfiguration
CWE	CWE-200 (Exposure of Sensitive Information), CWE-497 (Exposure of Sensitive System Information to an Unauthorized Control Sphere)
NIST	NIST SP 800-82 Rev. 3 (Guide to OT Security)

Descripción técnica

La página 'Infraestructura estratégica' exponía, sin autenticación, el endpoint infrastructure-status.php con un JSON que revelaba el segmento de red operacional (operations_segment: 10.40.20.0/24), la ruta de aplicación interna (application_route: /operations/gateway.php), el servicio upstream (ot-sim) y el dispositivo objetivo (RTU-GW-07) — información de arquitectura interna de la red OT que no debería ser pública desde el segmento corporativo/IT.

Evidencia

Bandera confirmada vía encabezado HTTP X-Interafas-Validation en la respuesta de infrastructure-status.php (X-Interafas-Diagnostic-Scope: infrastructure-status). Captura del JSON completo (sesión del 10/10/2026).

PASO 1 **Página del Centro de Operaciones con metadatos de diagnóstico expuestos**

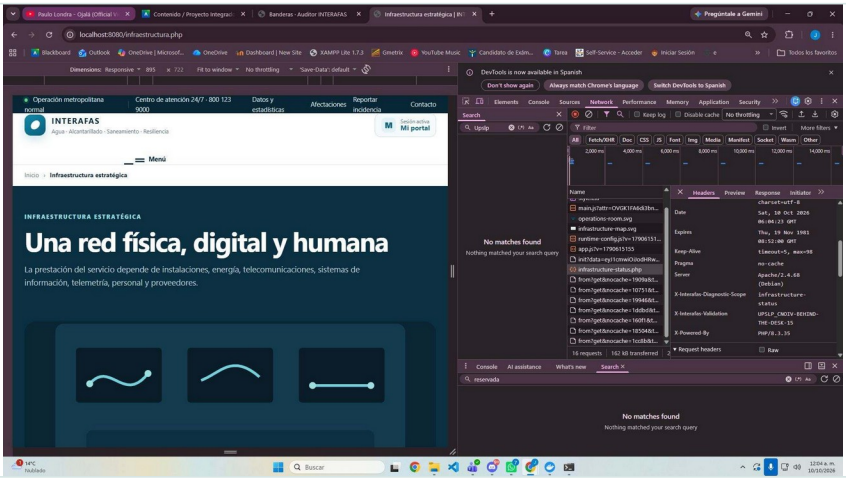


Figura 15.1 — captura de la sesión de explotación.

PASO 2 **Inspección de la respuesta completa del servicio de estado en DevTools**

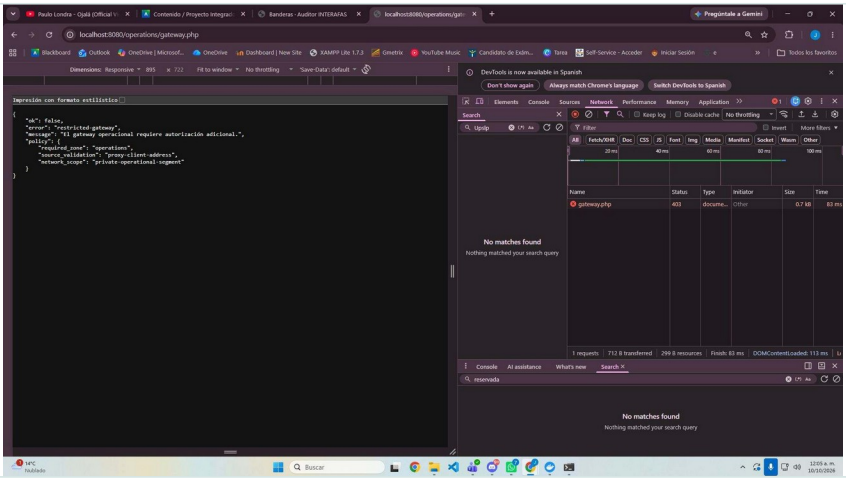


Figura 15.2 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad de la arquitectura de red: revela el mapa de red OT y las rutas internas necesarias para planear un ataque dirigido IT→OT, como ocurrió en los retos subsecuentes.

Remediación recomendada

Nunca exponer topología de red, direccionamiento interno ni rutas de aplicaciones operacionales en endpoints accesibles desde la red corporativa; segmentar y requerir autenticación fuerte para cualquier panel de diagnóstico.

HALLAZGO 5.16

[UPSLP_CNOIV-BEYOND-THE-WEB-16] Acceso indebido al gateway operacional (bypass de autenticación por cabecera confiada)

Nombre corto	BEYOND-THE-WEB
Categoría	IT → OT
Dificultad	★★★★☆ (4/5)
OWASP	A07:2021 - Identification and Authentication Failures
CWE	CWE-290 (Authentication Bypass by Spoofing)
MITRE ATT&CK ICS	MITRE ATT&CK ICS - T0859 Valid Accounts / técnica de suplantación de origen de red
NIST	NIST SP 800-82 Rev. 3

Descripción técnica

El endpoint /operations/gateway.php confiaba en la cabecera HTTP X-Forwarded-For para determinar si la petición provenía de la red operacional (10.40.20.0/24, segmento descubierto en el reto anterior). Añadiendo manualmente esa cabecera (x-forwarded-for: 10.40.20.10) desde la consola del navegador, una petición originada realmente en la red corporativa (172.18.0.1) fue tratada como si proviniera del segmento OT de confianza, devolviendo acceso y el enlace al panel operativo (/operations/login.php).

Evidencia

Bandera confirmada vía encabezado HTTP X-Interafas-Validation (X-Interafas-Boundary: crossed). Captura de la petición modificada en DevTools y la respuesta JSON con source.trusted_client: 10.40.20.10 (sesión del 10/10/2026).

PASO 1 **Petición original al gateway operacional (acceso denegado)**

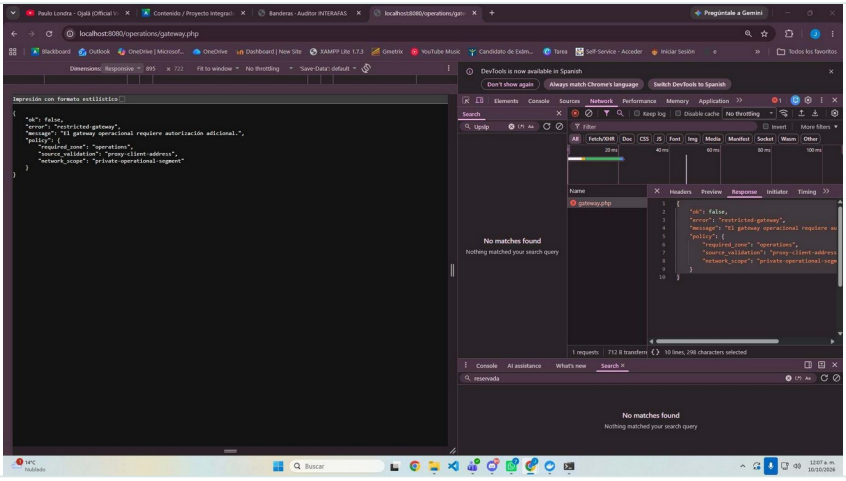


Figura 16.1 — captura de la sesión de explotación.

PASO 2 **Edición de la cabecera X-Forwarded-For en DevTools**

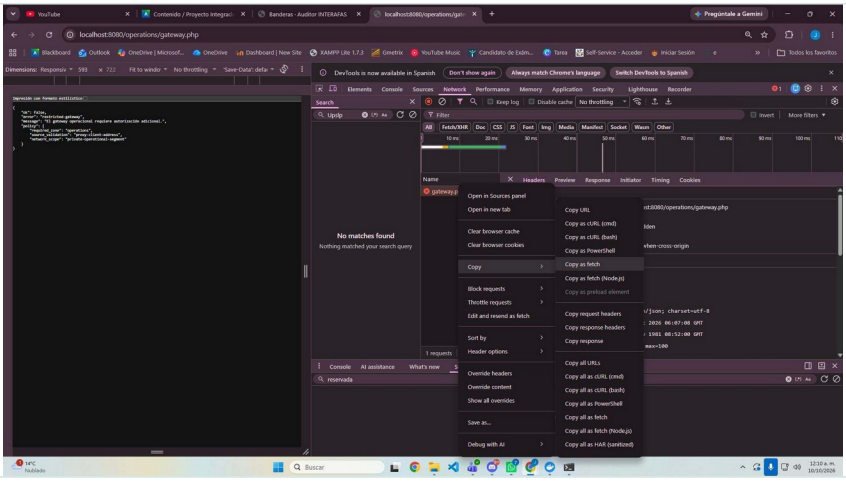


Figura 16.2 — captura de la sesión de explotación.

PASO 3 **Acceso concedido tras falsificar el origen de confianza**

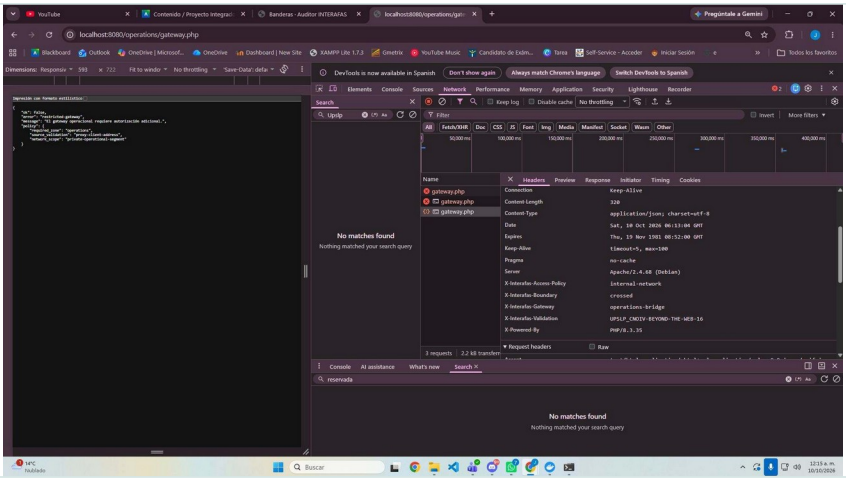


Figura 16.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad e Integridad: compromete la segmentación IT/OT, el control fundamental de seguridad en infraestructura crítica (defensa en profundidad según el modelo Purdue), permitiendo a un atacante en la red corporativa alcanzar la red operacional.

Remediación recomendada

Nunca confiar en cabeceras HTTP controlables por el cliente (X-Forwarded-For) para decisiones de autenticación/autorización de zona de red; la validación de origen debe hacerse a nivel de infraestructura de red (firewall/proxy que reescriba la cabecera en el borde real de confianza, nunca heredada del cliente).

HALLAZGO 5.17

[UPSLP_CNOIV-EYES-ON-THE-PLANT-17] Acceso no autorizado a la vista HMI (función crítica sin autenticación)

Nombre corto	EYES-ON-THE-PLANT
Categoría	OT simulado
Dificultad	★★★★☆ (4/5)
OWASP	A07:2021 - Identification and Authentication Failures
CWE	CWE-306 (Missing Authentication for Critical Function)
MITRE ATT&CK ICS	MITRE ATT&CK ICS - T0886 Remote Services / TA0108 Collection
NIST	NIST SP 800-82 Rev. 3, NIST SP 800-53 IA-2

Descripción técnica

Tras alcanzar /operations/login.php (el punto de entrada legítimo de la red OT), se identificó en el archivo JavaScript del cliente ops-client.js la referencia al endpoint telemetryEndpoint: /operations/telemetry.php. Navegando directamente a esa ruta, sin sesión ni credenciales de ningún tipo, el servidor devolvió telemetría completa de planta (presión, flujo, estado de válvulas y datos de firmware del dispositivo RTU-GW-07).

Evidencia

Bandera confirmada vía encabezados HTTP X-Interafas-Monitoring-Authorization: network-only y X-Interafas-Operational-Session: missing. Captura de la respuesta JSON completa de telemetry.php (sesión del 10/10/2026).

PASO 1 **Centro de Operaciones alcanzado tras el bypass del reto anterior**

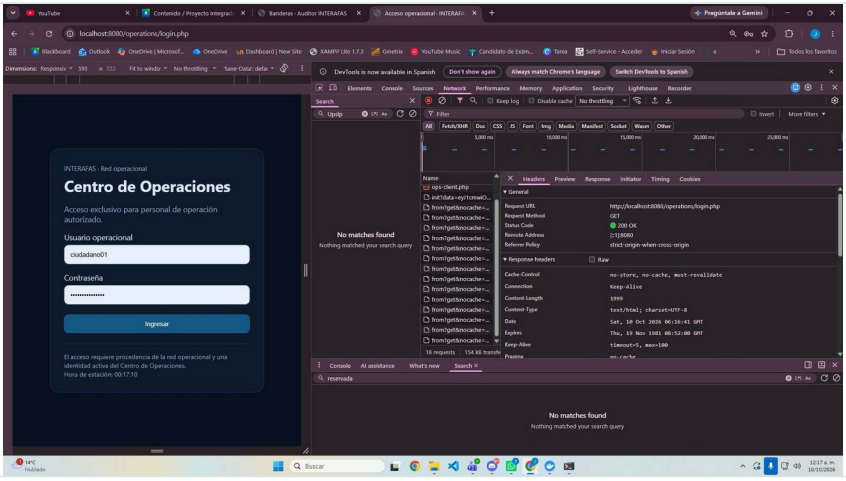


Figura 17.1 — captura de la sesión de explotación.

PASO 2 **Endpoint de telemetría no autenticado localizado en el código cliente**

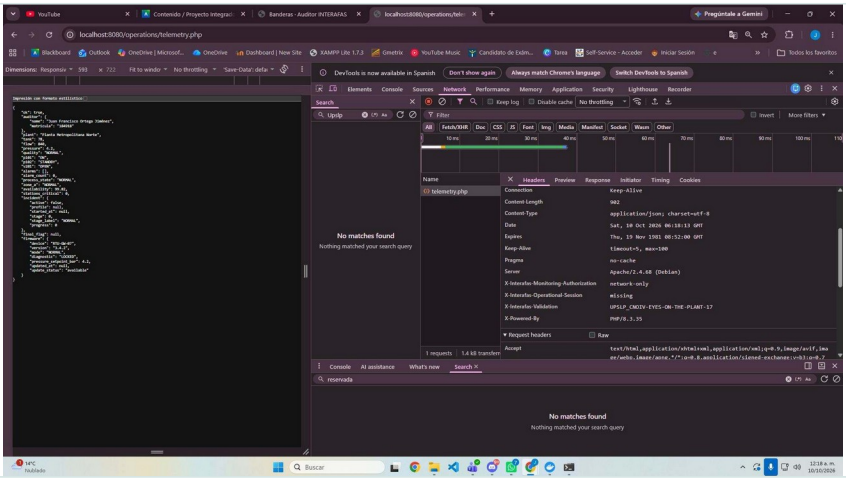


Figura 17.2 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad: expone en tiempo real el estado operativo de la planta simulada a cualquiera que alcance el segmento de red, sin ningún control de autenticación por sesión.

Remediación recomendada

Exigir autenticación y autorización de sesión en toda función de monitoreo o control, independientemente del segmento de red desde el que se origine la petición; el control de red (firewall) nunca debe ser el único control de acceso a una función crítica.

HALLAZGO 5.18

[UPSLP_CNOIV-TRUST-THE-PACKAGE-18] Validación defectuosa de firmware simulado (bypass de verificación de firma)

Nombre corto	TRUST-THE-PACKAGE
Categoría	Firmware simulado
Dificultad	★★★★★ (5/5)
OWASP	A08:2021 - Software and Data Integrity Failures
CWE	CWE-345 (Insufficient Verification of Data Authenticity), CWE-347 (Improper Verification of Cryptographic Signature)
MITRE ATT&CK ICS	MITRE ATT&CK ICS - T0857 System Firmware / T1593 (recon) y T1110 (fuerza bruta de credenciales, fase previa)
NIST	NIST SP 800-193 (Platform Firmware Resiliency Guidelines)

Descripción técnica

El manifiesto de actualización de firmware (/operations/updates/manifest.php) exponía un valor verification_ref (hash SHA-1 de una contraseña de soporte) y declaraba que el paquete solo se verificaba por checksum SHA-256 del payload, no por firma criptográfica de autenticidad. Mediante un ataque de máscara dirigido con hashcat (-m 100 -a 3 'Soporte?d?d?d') se recuperó la credencial soporte.ot:Soporte343 (verificada de forma independiente recalculando su SHA-1 y confirmando coincidencia exacta con verification_ref antes de usarla). Con esa credencial y la cabecera de origen de red ya comprometida (reto 16), se descargó el paquete legítimo, se modificó su payload (de {mode:NORMAL,diagnostic:LOCKED} a {mode:MAINTENANCE,diagnostic:UNLOCKED}), se recalculó el SHA-256 del nuevo contenido, y se envió por POST a /operations/updates/install.php. El servidor aceptó el paquete modificado porque solo validaba la integridad del checksum (que coincidía, al haber sido recalculado), sin verificar la autenticidad/firma del origen.

Evidencia

Bandera confirmada vía encabezado HTTP X-Interafas-Validation: UPSLP_CNOIV-TRUST-THE-PACKAGE-18, junto con X-INTERAFAS-Firmware-Verification: checksum-only y X-INTERAFAS-Signature-Verification: not-performed. Respuesta JSON completa de install.php con verification.authenticity: not-verified (sesión del 11/10/2026).

PASO 1 **Inicio del ataque de fuerza bruta dirigida con hashcat**

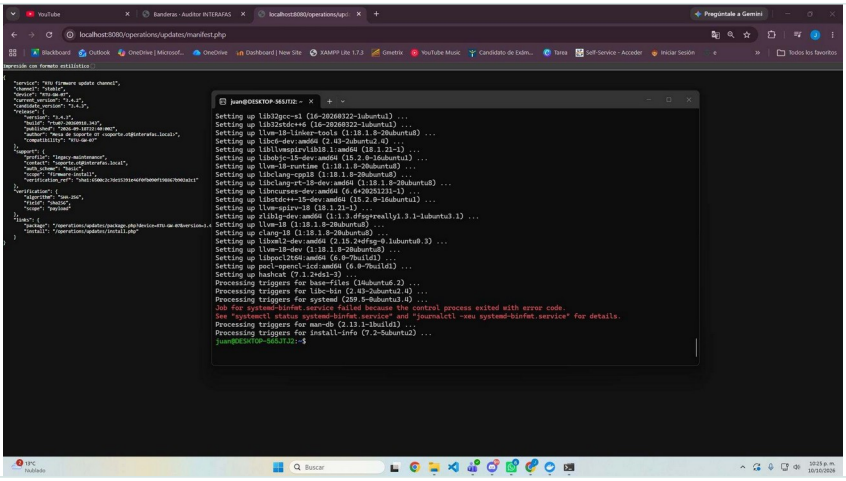


Figura 18.1 — captura de la sesión de explotación.

PASO 2 Panel del Auditor y lista de credenciales candidatas descifradas

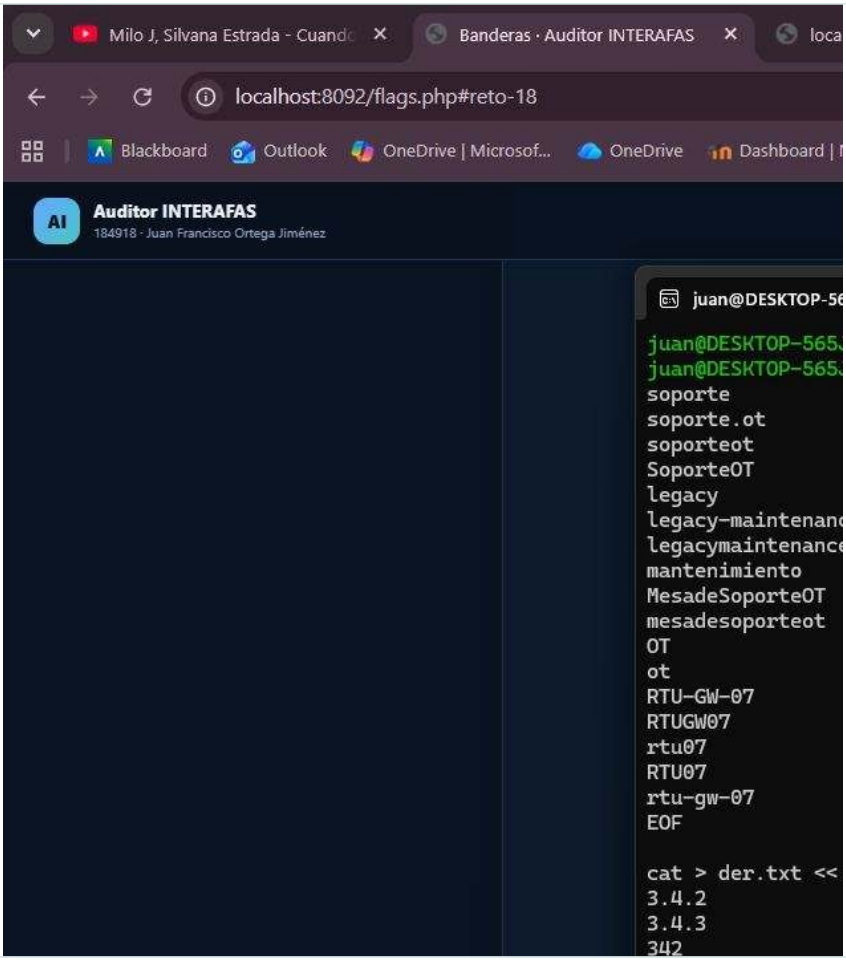


Figura 18.2 — captura de la sesión de explotación.

PASO 3 Contraseña de la cuenta de mantenimiento recuperada



Figura 18.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Integridad crítica: permite instalar firmware/configuración arbitraria en un dispositivo OT simulado sin ninguna verificación de que el paquete provenga de una fuente autorizada, habilitando manipulación completa del comportamiento del dispositivo (como se explota en los retos 19 y 20).

Remediación recomendada

Implementar verificación de firma criptográfica (no solo checksum de integridad) sobre todo paquete de firmware antes de instalarlo, con llave pública embebida en el dispositivo y cadena de confianza gestionada fuera de banda (alineado a NIST SP 800-193); además, eliminar por completo cualquier mecanismo de credenciales débiles de soporte/legacy para funciones de instalación de firmware.

HALLAZGO 5.19

[UPSLP_CNOIV-CHAIN-REACTION-19] Encadenamiento de hallazgos IT→OT: exceso de privilegio en sesión de mantenimiento

Nombre corto	CHAIN-REACTION
Categoría	Cadena de ataque
Dificultad	★★★★★ (5/5)
OWASP	A01:2021 - Broken Access Control
CWE	CWE-285 (Improper Authorization), CWE-863 (Incorrect Authorization) - violación del principio de mínimo privilegio
MITRE ATT&CK ICS	MITRE ATT&CK ICS - T0840 Network Connection Enumeration, TA0102 Discovery
NIST	NIST SP 800-82 Rev. 3; OWASP Authorization Cheat Sheet / Testing for Bypassing Authorization Schema

Descripción técnica

Usando exclusivamente la sesión de mantenimiento obtenida en el reto 18 (credencial soporte.ot, cuyo manifiesto de firmware declaraba explícitamente scope: firmware-install), se navegó el panel 'Assets' del HMI y se recorrió la cadena de dependencias operacional completa: RTU-GW-07 (gateway) → PLC-SL-01 (control, Saint Louis) → P-SL-101 (bombeo primario) → HDR-SL-01 (cabezal hidráulico que recibe la descarga) → V-SL-201 (válvula de distribución Zona A) → ZONE-SL-A (zona de servicio). Cada salto se confirmó contra el servidor vía peticiones reales a /operations/asset-context.php, validadas en el indicador ЦЕПОЧКА ЗАВИСИМОСТЕЙ hasta alcanzar ЗАВЕРШЕНО · 6/6.

Evidencia

Bandera confirmada vía encabezado HTTP X-Interafas-Validation: UPSLP_CNOIV-CHAIN-REACTION-19 en la última petición a asset-context.php?asset=ZONE-SL-A, junto con X-Interafas-Authorization-Scope: exceeded y X-Interafas-Dependency-Chain: complete. Capturas de cada salto de la cadena (sesión del 11/10/2026).

PASO 1 **Mapa de red operacional y relaciones entre activos**

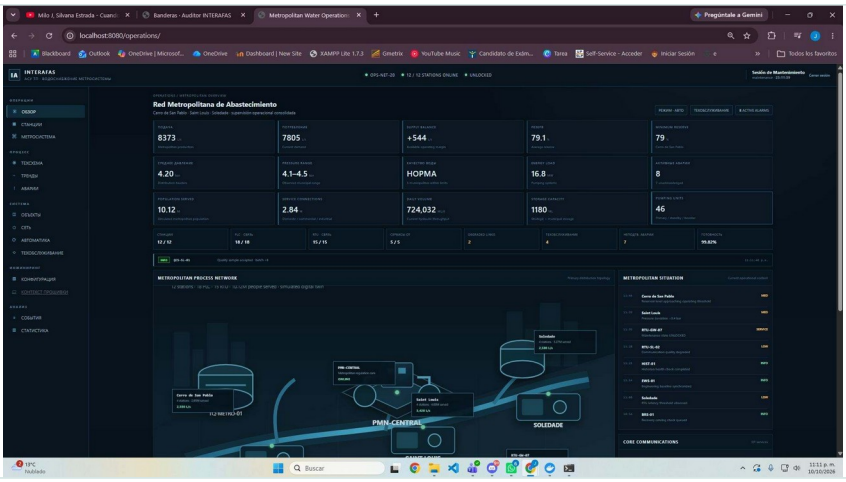


Figura 19.1 — captura de la sesión de explotación.

PASO 2 **Exploración del grafo de dependencias OT (Asset Context)**

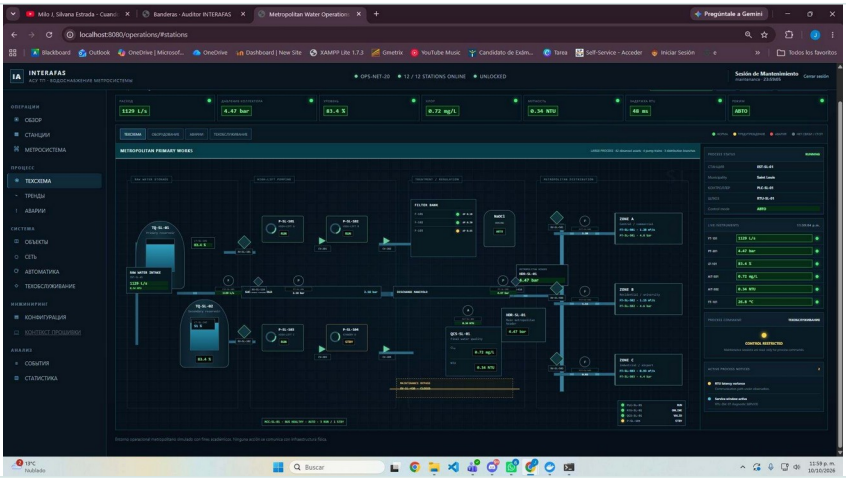


Figura 19.2 — captura de la sesión de explotación.

PASO 3 **Cadena de 6 saltos / 37 activos recorrida con una sesión de alcance limitado**

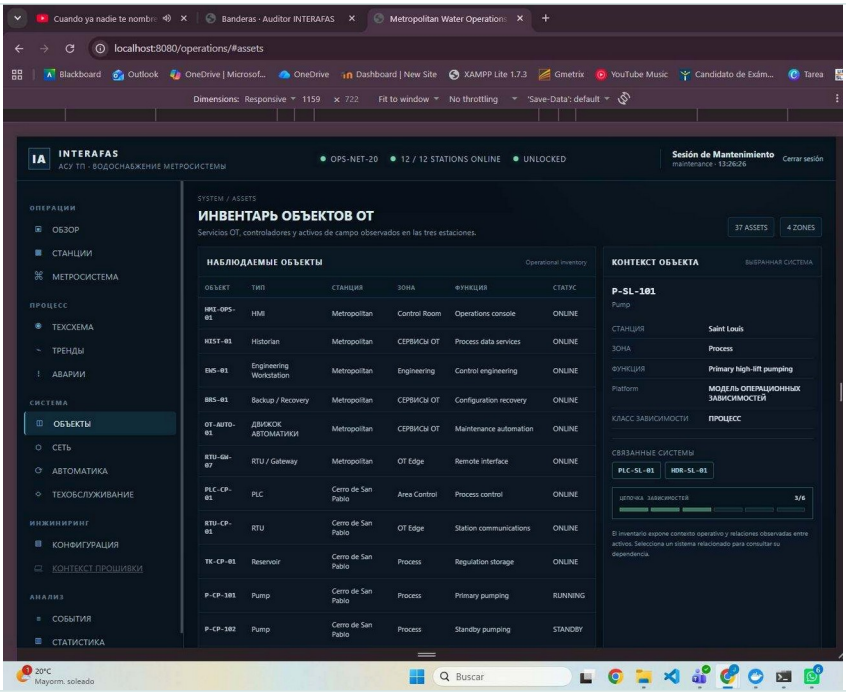


Figura 19.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Confidencialidad: una sesión cuyo propósito declarado era exclusivamente instalar firmware (ámbito 'firmware-install') pudo recorrer libremente todo el inventario y grafo de dependencias de la red operacional (37 activos, 4 zonas de servicio), excediendo por completo el alcance autorizado para ese rol. Esto es la violación del principio de mínimo privilegio documentada explícitamente por el propio sistema en el encabezado X-Interafas-Authorization-Scope: exceeded.

Remediación recomendada

Diseñar los roles y sesiones de mantenimiento con autorización de grano fino (scope-based authorization) que restrinja, a nivel de servidor, exactamente las operaciones y recursos declarados para

esa sesión (en este caso, únicamente instalación de firmware sobre el dispositivo específico), rechazando cualquier otra operación aunque la sesión esté técnicamente autenticada.

HALLAZGO 5.20

[UPSLP_CNOIV-NOW-YOU-CONTROL-20] Impacto operacional final: manipulación de parámetro crítico sin validación de rango

Nombre corto	NOW-YOU-CONTROL
Categoría	OT simulado
Dificultad	★★★★★ (5/5)
OWASP	A08:2021 - Software and Data Integrity Failures (continuación del reto 18)
CWE	CWE-20 (Improper Input Validation), CWE-1284 (Improper Validation of Specified Quantity in Input) - ausencia de validación de rango físico/operacional seguro
MITRE ATT&CK ICS	MITRE ATT&CK ICS - T0836 Modify Parameter, T1693 Modify Firmware (relacionado con el vector del reto 18)
NIST	NIST SP 800-82 Rev. 3; NIST SP 800-193

Descripción técnica

Con el menú de Firmware habilitado tras completar la cadena de dependencias (reto 19), se descargó el respaldo de configuración vigente del dispositivo RTU-GW-07 (pressure_setpoint_bar: 4.2, el baseline validado de ingeniería). Se modificó únicamente ese parámetro a un valor claramente fuera de rango operacional seguro (9.8 bar), dejando intactos los demás campos (device, version, mode, diagnostic), y se cargó el JSON modificado desde el panel de Firmware. El sistema no realizó ninguna validación de rango físico/operacional sobre el nuevo valor antes de aplicarlo al dispositivo.

Evidencia

Bandera UPSLP_CNOIV-NOW-YOU-CONTROL-20 confirmada automáticamente en el encabezado principal del HMI al alcanzar el estado 'CATASTROPHIC STATE'. Capturas del backup original (4.2 bar), el paquete modificado (9.8 bar) y la cascada de fallo resultante: escalada progresiva de alarmas (de ~0 hasta 6,842 averías activas) y caída de disponibilidad operativa (de 99.82% a 4.10%) en intervalos de aproximadamente 3 segundos, propagándose a las 12 estaciones de la red simulada (sesión del 11/10/2026).

PASO 1 **Actualización de firmware con el paquete modificado**

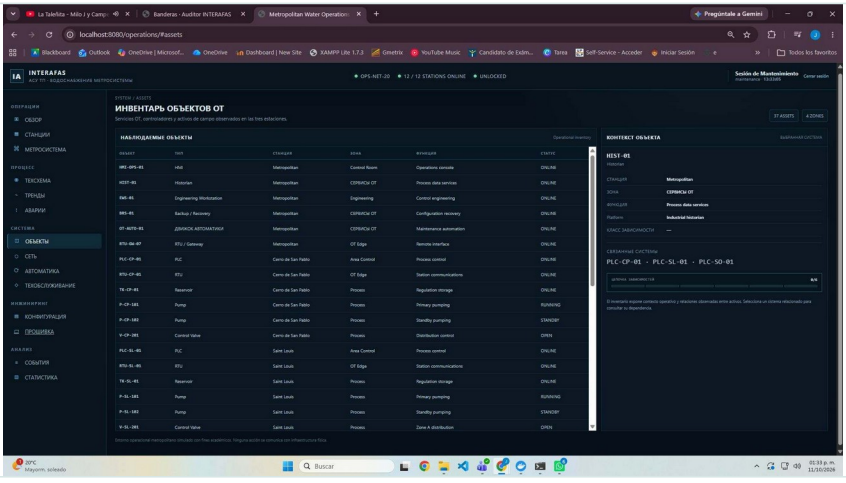


Figura 20.1 — captura de la sesión de explotación.

PASO 2 **Panel HMI en estado operativo normal**

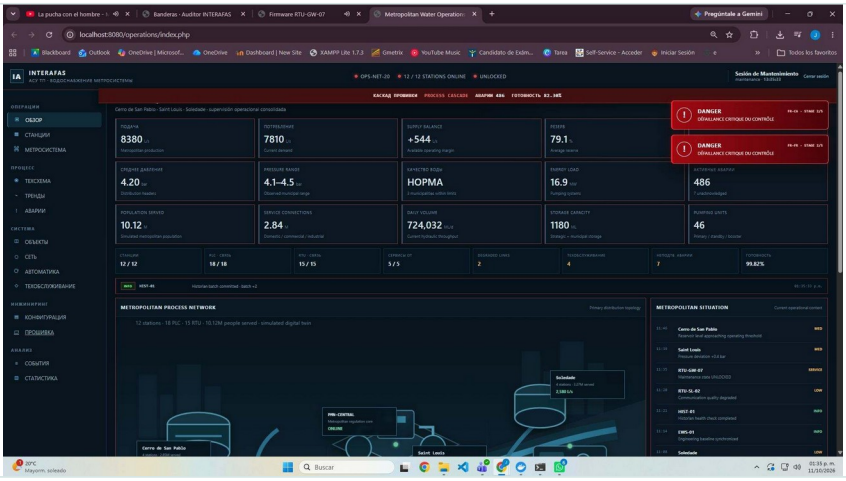


Figura 20.2 — captura de la sesión de explotación.

PASO 3 **Estado de alarma en cascada tras la manipulación del parámetro de presión**

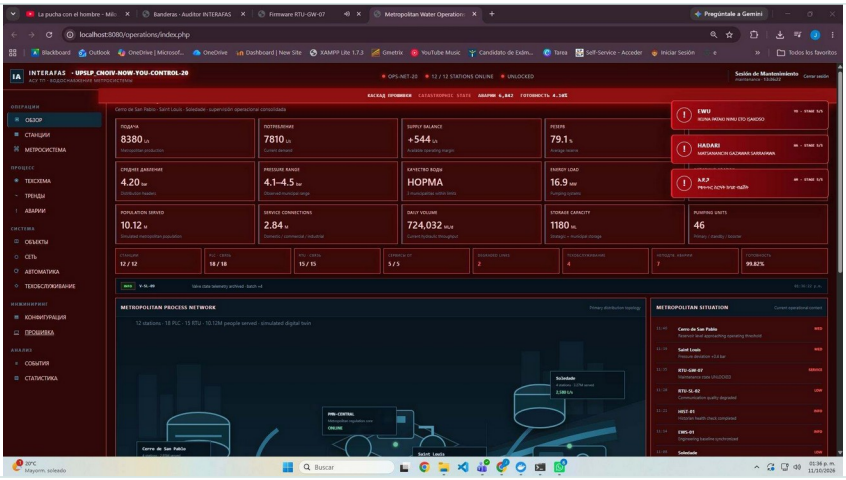


Figura 20.3 — captura de la sesión de explotación.

Impacto (tríada CIA)

Disponibilidad crítica (el tercer pilar de la tríada CIA, el más relevante en contextos OT): un solo parámetro operacional sin validar provocó el colapso en cascada de toda la red de distribución de agua simulada, demostrando cómo la cadena completa de hallazgos (16→17→18→19→20) escala de un problema de exposición de información a un impacto operacional real sobre un servicio de infraestructura crítica.

Remediación recomendada

Validar todo parámetro operacional recibido contra límites físicos/de ingeniería seguros (rango mínimo-máximo) antes de aplicarlo a cualquier dispositivo, tanto en el servidor como, idealmente, con enclavamientos (interlocks) a nivel de controlador físico que no dependan exclusivamente del software de gestión; aplicar además control de cambios (change management) y doble verificación humana para modificaciones de parámetros críticos de proceso.

06

Narrativa de cadena de ataque IT → OT (retos 16-20)

Los hallazgos 16 a 20 no son incidentes aislados: constituyen una cadena de ataque coherente que ilustra cómo un atacante que compromete la red corporativa (IT) puede escalar progresivamente hasta obtener control operacional sobre infraestructura crítica (OT), siguiendo el modelo de referencia Purdue de segmentación industrial.

Paso 1 — Reto 16 (BEYOND-THE-WEB): Bypass de autenticación por cabecera confiada (CWE-290): se falsifica la cabecera X-Forwarded-For para hacer creer al gateway operacional que la petición proviene del segmento OT de confianza (10.40.20.0/24), obteniendo acceso al punto de entrada /operations/login.php.

Paso 2 — Reto 17 (EYES-ON-THE-PLANT): Función crítica sin autenticación (CWE-306): desde el punto de entrada OT ya alcanzado, se descubre en el JavaScript del cliente un endpoint de telemetría (/operations/telemetry.php) accesible sin sesión, exponiendo el estado operativo completo de la planta.

Paso 3 — Reto 18 (TRUST-THE-PACKAGE): Verificación de firmware insuficiente (CWE-345/347): se recupera por fuerza bruta dirigida (hashcat) la credencial de mantenimiento soporte.ot, verificada contra el hash publicado en el manifiesto de actualización. Con ella se instala un paquete de firmware modificado, aceptado porque el servidor solo valida checksum de integridad, no firma de autenticidad.

Paso 4 — Reto 19 (CHAIN-REACTION): Exceso de privilegio (CWE-285/863): la sesión de mantenimiento, cuyo alcance declarado era exclusivamente 'firmware-install', se utiliza para recorrer libremente todo el grafo de dependencias operacionales (6 saltos, 37 activos), confirmando la violación del principio de mínimo privilegio.

Paso 5 — Reto 20 (NOW-YOU-CONTROL): Validación de rango insuficiente (CWE-20/1284): aprovechando el acceso de firmware ya obtenido, se modifica el parámetro pressure_setpoint_bar a un valor fuera de rango operacional seguro, provocando el colapso en cascada de la red de distribución simulada (hasta 6,842 averías activas y 4.10% de disponibilidad).

Esta cadena demuestra el principio central de la seguridad en sistemas ciberfísicos: una vulnerabilidad de exposición de información aparentemente menor (reto 15, descubrimiento de arquitectura interna) puede, combinada con fallas de autenticación y ausencia de validación de rango, escalar hasta un impacto real sobre la disponibilidad de un servicio de infraestructura crítica.

07

Conclusiones y recomendaciones generales

El ejercicio permitió completar el 100% de los hallazgos planteados (20/20, 65/65 puntos técnicos ponderados por complejidad), evidenciando debilidades representativas de las categorías más comunes del OWASP Top 10 y del OWASP API Security Top 10, así como una cadena de ataque realista IT→OT alineada con técnicas documentadas en MITRE ATT&CK for ICS.

Las recomendaciones generales, derivadas del conjunto de hallazgos, son:

- Adoptar el principio de mínimo privilegio y autorización de grano fino en todo mecanismo de sesión, especialmente en roles de mantenimiento/soporte con alcance declarado.
- Eliminar toda dependencia de controles de red (cabeceras, segmentación) como único mecanismo de autenticación/autorización de funciones críticas.

- Implementar verificación criptográfica de firma (no solo checksum) en todo proceso de actualización de firmware, conforme a NIST SP 800-193.
- Validar rangos físicos/operacionales seguros en todo parámetro de proceso antes de aplicarlo a un dispositivo OT, con enclavamientos independientes del software de gestión.
- Fortalecer la gestión de sesión, el manejo de errores y la validación de entrada en la capa de aplicación web corporativa (IT), dado que fue el punto de entrada de toda la cadena de compromiso hacia OT.

Este informe se entrega como parte del producto académico PR02 de la asignatura Sistemas de Gestión de la Seguridad, UPSLP, y se complementa con el documento de SGSI (ISO/IEC 27001), el plan de comunicación de crisis, el plan de respuesta a incidentes y el paquete de evidencia con matrícula.